



Confidentiality policies and procedures for all City of Philadelphia workforce members who create, use, maintain, or share health information.

v.120117

HIPAA POLICY MANUAL



TABLE OF CONTENTS

CONTENTS

1.0	Introduction	3
1.1	WHY PRIVACY IS IMPORTANT	3
1.2	WHAT IS HIPAA	3
1.3	WHO MUST FOLLOW THESE POLICIES AND PROCEDURES	4
1.4	RELATIONSHIP TO OTHER POLICIES	4
2.0	Key Terms	5
2.1	DEFINITIONS	5
2.2	ACRONYMS	7
3.0	Recognizing What Information Is Protected	8
3.1	THE CITY'S HYBRID STATUS	8
3.2	DEFINING PROTECTED HEALTH INFORMATION AND DESIGNATED RECORDS SETS	10
3.3	HIGHLY CONFIDENTIAL INFORMATION	12
3.4	DE-IDENTIFIED DATA AND LIMITED DATA SETS	14
4.0	Ground Rules for Working with PHI	16
4.1	THE MINIMUM NECESSARY STANDARD	16
4.2	VERIFYING THE RECIPIENT	18
4.3	TRACKING DISCLOSURES	20
5.0	Permitted Uses and Disclosures	23
5.1	PERMITTED USES	23
5.2	PERMITTED DISCLOSURES	25
5.3	CONSENT/AUTHORIZATION	26
5.4	FAMILY AND OTHERS INVOLVED IN THE INDIVIDUAL'S CARE	29
5.5	TREATMENT, PAYMENT, AND HEALTH CARE OPERATIONS	31
5.6	BUSINESS ASSOCIATES	33
5.7	PUBLIC HEALTH AND SAFETY REPORTING	36
5.8	COURT ORDERS, SUBPOENAS, AND WARRANTS	39
5.9	RESEARCH	42
5.10	OTHER REASONS FOR DISCLOSING PHI	44
6.0	Safeguarding Protected Health Information	46
7.0	Reporting Incidents	49
8.0	Honoring an Individual's Rights	52
8.1	RIGHT TO DESIGNATE A PERSONAL REPRESENTATIVE	52
8.2	RIGHT TO ACCESS, INSPECT, AND OBTAIN A COPY	55

TABLE OF CONTENTS

8.3	RIGHT TO CORRECT ERRORS	58
8.4	RIGHT TO KNOW HOW HEALTH INFORMATION IS USED OR DISCLOSED	60
8.5	RIGHT TO LIMIT CERTAIN USES AND DISCLOSURES	62
8.6	RIGHT TO FILE A COMPLAINT	64
9.0	Administration and Training	65
9.1	HIPAA OFFICIALS	65
9.2	TRAINING AND EDUCATION	66
9.3	SANCTIONS	67
9.4	ANTI-RETALIATION	69
9.5	HIPAA DOCUMENTATION	69
10.0	Contact Information	71
	City HIPAA Forms	72
	FORM 7.0: INCIDENT REPORT FORM	72

This Manual and its contents were created exclusively for the City of Philadelphia. For permission to use or disclose the contents of this Manual outside the City of Philadelphia, please contact HIPAAprivacy@phila.gov.

INTRODUCTION

1.0 Introduction

1.1 WHY PRIVACY IS IMPORTANT

Many City services expose workforce members to private aspects of other people's lives during vulnerable times. Health records in particular can include some of the most intimate details about a person's life, documenting a person's physical and mental health, social behaviors, personal relationships, and financial status. When people use City services or receive City health insurance benefits, they trust the City to respect their privacy rights by maintaining the confidentiality and security of their personal information.

There are a number of reasons that privacy, confidentiality, and security are important to the City:

- Confidentiality is essential to **build trusting relationships** with individuals receiving care, often members of vulnerable communities who have experienced stigma and discrimination.
- Patients who believe that health services are confidential are **more likely to seek care**, particularly for reproductive health, mental health, or substance abuse matters.
- Giving an individual control over his or her personal information **encourages autonomy and active participation** in managing one's own health care.
- Privacy violations and security breaches **cause the individual to suffer** financial harm, anxiety, and embarrassment, and in some cases, may jeopardize the individual's immigration status, child custody, ability to obtain insurance coverage, employment eligibility, or access to benefits.

A major goal of this Manual is to assure that individuals' confidential information is properly protected while allowing the flow of health information needed to provide and promote high quality health care and to protect the public's health and well-being. This Manual provides guidance on how to get your job done while meeting legal requirements and protecting the privacy of people who receive City services or benefits.

1.2 WHAT IS HIPAA

There are numerous federal and state laws that regulate the privacy and security of health and medical records. These laws involve three interconnected concepts:

- **Privacy** refers to an individual's right to control his or her own person, personal matters, and information. Privacy laws such as HIPAA specify who can access other people's personal information and under what conditions. Organizations adopt privacy policies to ensure personal information is collected, stored, and used for appropriate reasons and that individuals have rights to control their own personal information.
- **Confidentiality** focuses on preventing personal information exchanged in confidence from being divulged to third parties. Professionals such as clinicians, counselors, attorneys, researchers, public health and social workers have legal and ethical obligations to maintain the confidentiality of personal information they collect or access as part of their jobs.
- **Security** involves procedural and technical measures that prevent unauthorized access to confidential information and protect the integrity and availability of records maintained electronically.

HIPAA (the Health Insurance Portability and Accountability Act of 1996, as amended by the Health Information Technology for Economic and Clinical Health Act of 2009) is a federal law that establishes a national standard for the privacy and security of health information. Regulations issued under HIPAA (the "HIPAA Rules") include:

- The **Privacy Rule**, which sets limits and conditions on the uses and disclosures that may be made of an individual's personal health information without the individual's permission and gives individuals rights over their health information, including rights to examine, obtain a copy of, and correct their records.
- The **Security Rule**, which requires appropriate administrative, physical and technical safeguards to ensure the confidentiality, integrity, and security of electronic protected health information.

INTRODUCTION

- The **Breach Notification Rule**, which requires HIPAA covered entities and their business associates to provide notification following a breach of unsecured protected health information.

Other federal and state laws contain additional requirements protecting specific types of highly confidential health information. If HIPAA and one of these laws apply to the same records and their requirements conflict, we must follow the law that is most protective of the individual who is the subject of the record.

1.3 WHO MUST FOLLOW THESE POLICIES AND PROCEDURES

All workforce members within the City designated health care component are required to comply with the policies and procedures in this Manual. This includes all workforce members of Covered Units, and any workforce members of Support Units who have access to protected health information. [Table 3.1](#) lists the Covered Units and Support Units (current as of the last revision date of this Manual).

1.4 RELATIONSHIP TO OTHER POLICIES

City departments, divisions, and units may institute additional confidentiality policies and procedures addressing topics specific to their workplace environment. Covered and Support Units are also expected to develop HIPAA protocols supplementing this Manual when unit-specific procedures are needed. As a City-wide policy approved by the HIPAA Steering Committee, this Manual takes precedence over any departmental or unit-specific policies, procedures, or protocols that conflict with this Manual.

Covered Units are expected to develop and maintain the departmental/unit-specific HIPAA protocols listed below:

1. Designated Record Sets – see [Section 3.2](#)
2. Role-Based Access – see [Section 4.1](#)
3. Routine Disclosures (optional) – see [Section 4.1](#)
4. Mandatory Reporting – see [Section 5.7](#)
5. Responding to Individual Requests for Access (optional) – see [Section 8.2](#)
6. Responding to Individual Requests for Correction (optional) – see [Section 8.3](#)
7. Responding to Individual Requests for Restrictions or Confidential Communications (optional) – see [Section 8.5](#)

KEY TERMS

2.0 Key Terms

The definitions below apply whenever these terms are used throughout the Manual, whether they appear with initial capitals ("Protected Health Information") or in lowercase form ("protected health information").

2.1 DEFINITIONS

Authorization: a document signed and dated by the individual consenting to certain uses and disclosures of his or her protected health information that contains all elements required by HIPAA (see [Section 5.3](#)).

Breach: the acquisition, access, use, or disclosure of protected health information in a manner that (1) is not permitted under the HIPAA Rules and (2) compromises the privacy or security of the PHI, as determined by a risk assessment conducted by the City HIPAA Privacy Officer.

Business Associate: Any person or entity (outside of the City workforce) that:

8. creates, receives, maintains, or transmits PHI on behalf of a Covered Unit to perform a function or activity regulated by HIPAA, including claims processing or administration, data analysis, processing or administration, utilization review, quality assurance, patient safety activities, billing, benefit management, practice management, or repricing;
9. provides services to or for the Covered Unit involving access to PHI, including legal, actuarial, accounting, consulting, data aggregation, management, administrative, accreditation, or financial services; or
10. is responsible for creating, receiving, maintaining, or transmitting a Covered Unit's PHI on behalf of a Support Unit or another Business Associate (i.e., a subcontractor that is assisting a Support Unit or other Business Associate with the activities described above).

City PHI: PHI that is transmitted or maintained by a Covered Unit, or by a Support Unit or business associate on behalf of a Covered Unit.

Covered Entity: an entity that is subject to HIPAA because it performs certain health care functions. The City is a covered entity for HIPAA compliance purposes. Because the City is a hybrid entity, only those departments, divisions, units, and workforce members within the City's designated health care component are subject to HIPAA requirements. See [Table 3.1](#).

Covered Unit: any City department, division, or unit that if standing alone, would be a covered entity. Also referred to as a "Health Care Component" in Executive Order No. 4-17: HIPAA Compliance Directive. Covered Units are listed in [Table 3.1](#) and at www.phila.gov/privacy.

Designated Health Care Component: the portion of the City that is subject to the HIPAA Rules, including all workforce members of Covered Units and any workforce members of Support Units who have access to City PHI.

Designated Record Set: a group of records maintained by or for a covered entity that may include patient medical and billing records; the enrollment, payment, claims, adjudication, and case or medical management record systems maintained by or for a health plan; or information used in whole or in part by a covered entity to make decisions about individuals' health care or health insurance benefits. As used in this definition, the term "record" means any item, collection, or grouping of information that includes PHI and is maintained, collected, used, or disseminated by or for a covered entity.

Health Care Operations: certain administrative, financial, legal, and quality improvement activities of a covered entity that are necessary to run its business and to support its core functions of treatment or payment for health care. These activities include:

1. Conducting quality assessment and improvement activities, population-based activities relating to improving health or reducing health care costs, and case management and care coordination;
2. Reviewing the competence or qualifications of health care professionals, evaluating provider and health plan performance, training health care and non-health care professionals, accreditation, certification, licensing, or credentialing activities;

KEY TERMS

3. Underwriting and other activities relating to the creation, renewal, or replacement of a contract of health insurance or health benefits, and ceding, securing, or placing a contract for reinsurance of risk relating to health care claims;
4. Conducting or arranging for medical review, legal, and auditing services, including fraud and abuse detection and compliance programs;
5. Business planning and development, such as conducting cost-management and planning analyses related to managing and operating the entity; and
6. Business management and general administrative activities, including those related to implementing and complying with the HIPAA Rules, customer service, resolution of internal grievances, sale or transfer of assets, creating de-identified health information or a limited data set, and fundraising for the benefit of the covered entity.

Health Care Provider: a licensed provider of medical or health services (for example, a hospital, skilled nursing facility, home health agency, hospice program, ambulance service, physician, nurse practitioner, physician assistant, nurse, physical therapist, psychologist, or clinical social worker), and any other person or organization who furnishes, bills, or is paid for health care in the normal course of business.

Highly Confidential Information: Health information that is protected under HIPAA and more restrictive federal or state confidentiality laws, such as HIV-related information, substance abuse treatment records, mental health treatment records, and clinical laboratory results (see [Section 3.3](#)).

HIPAA Documentation: documentation related to HIPAA compliance and administration, including but not limited to the following:

1. City HIPAA policies and procedures;
2. Unit-specific and departmental HIPAA policies, procedures, or protocols;
3. Any communication required by the HIPAA Rules (for example, requests by individuals and related correspondence, notices of privacy practices, etc);
4. Any action, activity, or designation that is required to be documented by the HIPAA Rules, (for example, employee disciplinary action records, risk assessment reports);
5. Incident documentation for any privacy and security incidents, and breach notification documentation for any privacy or security breaches (see [Section 7.0](#)); and
6. Business associate agreements with service providers and contractors.

HIPAA Rules: the Privacy Rule, Security Rule, and Breach Notification Rule issued under HIPAA, set forth in 45 CFR Part 160 and Part 164.

Incident: any acquisition, access, use, or disclosure of PHI in a manner not permitted under the HIPAA Rules, other privacy laws, an applicable BAA or MOU, or City or unit-specific privacy or security policies. The term “Incident” encompasses situations that could *potentially* compromise the privacy or security of PHI, in addition to situations that are determined to *actually* compromise its privacy or security.

Individual: the person who is the subject of protected health information.

Marketing: any communication about a product or service that encourages recipients to purchase or use the product or service, with certain exceptions (described at 45 CFR § 164.501).

Payment: the various activities of health care providers to obtain payment or be reimbursed for their services and of health plans to obtain premiums, to fulfill their coverage responsibilities and provide benefits under the plan, and to obtain or provide reimbursement for the provision of health care. Examples of common payment activities include:

1. Determining eligibility or coverage under a plan and adjudicating claims;
2. Risk adjustments;
3. Reviewing health care services for medical necessity, coverage, or justification of charges;

KEY TERMS

4. Billing and collection activities; and
5. Utilization review activities.

Privacy Liaison: the designated privacy official for a Support Unit

Privacy Officer: the designated privacy official for a Covered Unit

Protected Health Information or PHI: information transmitted or maintained in any form or medium by a covered entity or a business associate on its behalf, that:

1. was created or received by a health care provider, health plan, employer, or health care clearinghouse;
2. relates to the physical or mental health or condition of an individual, the provision of health care to an individual, or the payment for the provision of health care to an individual; and
3. identifies the individual or might reasonably be used to identify the individual.

PHI excludes (1) education records covered by the Family Educational Right and Privacy Act (FERPA); (2) records described at 20 U.S.C. 1232g(a)(4)(B)(iv); (3) employment records held by a covered entity in its role as employer; and (4) information related to individuals who have been deceased for more than 50 years.

Support Units: City departments, divisions, units, and workforce members that perform business, legal, financial, or administrative functions involving the use or disclosure of PHI on behalf of a Covered Unit. Support Units include those units listed in [Table 3.1](#), to the extent they perform support functions for a Covered Unit.

Treatment: the provision, coordination, or management of health care and related services among health care providers or by a health care provider with a third party, consultation between health care providers regarding a patient, or the referral of a patient from one health care provider to another.

Workforce Member: an employee, volunteer, trainee, and other person whose conduct, in the performance of work for the City, is under the direct control of the City, whether or not that person is paid by the City. The terms “Covered Unit workforce member” and “Support Unit workforce member” are also used in this policy to indicate workforce members of those respective units.

2.2 ACRONYMS

BAA: Business Associate Agreement

CHPO: City HIPAA Privacy Officer

CHSO: City HIPAA Security Officer

DHHS: The U.S. Department of Health and Human Services (the Federal agency that enforces HIPAA)

HIPAA: the Health Insurance Portability and Accountability Act of 1996, as amended by the Health Information Technology for Economic and Clinical Health Act of 2009

MOU: Memorandum of Understanding

PHI: Protected Health Information

RECOGNIZING WHAT INFORMATION IS PROTECTED

3.0 Recognizing What Information Is Protected

3.1 THE CITY'S HYBRID STATUS

A. Purpose

1. HIPAA applies to “covered entities,” which include health care providers that conduct certain types of transactions electronically, health plans, and health care clearinghouses.
2. If a single covered entity has a mix of functions – some that are subject to HIPAA and some that are not – the entity may choose to designate itself a “hybrid entity” thereby limiting its compliance responsibilities to only the HIPAA-covered functions (the “health care component”). The hybrid entity must designate as part of its health care component:
 - a. any department, division, or unit that if standing alone, would be a covered entity (a “**Covered Unit**”); and
 - b. any unit and workforce member that performs business, legal, financial, or administrative services or functions involving the use or disclosure of PHI on behalf of a Covered Unit (a “**Support Unit**”).
3. A hybrid entity is required to create adequate separation, in the form of firewalls, between the health care component(s) and other components of the entity. PHI held by a Covered or Support Unit can only be disclosed to another part of the hybrid entity to the same extent HIPAA permits such a disclosure to a separate entity.

B. Policy

1. The City is a **covered entity** because some of its departments, divisions, and units perform covered functions as health care providers or health plans.
2. In 2002, the City designated itself a **hybrid entity** because only certain portions of the City perform activities that make them subject to HIPAA. The City's hybrid designation was updated and formalized in Executive Order No. 4-17: HIPAA Compliance Directive, available at www.phila.gov/executiveorders. The designated units are listed in [Table 3.1](#) below.
3. The procedures below describe firewalls that must be implemented between departments, divisions, and units that are part of the City's health care component and those that are not.

C. Procedures

1. The City HIPAA Steering Committee will periodically review the City's hybrid designation and make revisions as needed. A current list of Covered Units will be posted at www.phila.gov/privacy.
2. From time to time, Support Units may be added to the City's health care component as follows:
 - a. Before a Covered Unit establishes a relationship with a new Support Unit involving the use or disclosure of PHI, the Covered Unit will notify the City HIPAA Privacy Officer (“CHPO”).
 - b. The CHPO will facilitate review, approval, and documentation by the HIPAA Steering Committee of the proposed Support Unit's inclusion in the City health care component.
 - c. The Covered Unit and new Support Unit will, with the assistance of the Law Department, execute a memorandum of understanding (“MOU”) outlining the services or functions that will be performed by the Support Unit, the PHI that may be shared with, accessed by, or created by the Support Unit, and how that PHI will be protected by the Covered Unit.
 - d. On an ongoing basis and to the extent it performs support functions, the Support Unit is responsible for complying with HIPAA, this Policy, the requirements of its MOU with the Covered Unit, and security requirements established by the City HIPAA Security Officer (“CHSO”). The Support Unit will (i) designate a HIPAA Liaison who will oversee HIPAA compliance and be accountable to the Covered Unit, the CHPO, and the CHSO; (ii) ensure all workforce members with access to PHI receive HIPAA training; and (iii) participate in audits and other compliance activities as directed by the CHPO and CHSO.

RECOGNIZING WHAT INFORMATION IS PROTECTED

3. Covered and Support Units will maintain operational separation from other departments, divisions, and units. In particular, each Covered or Support Unit will ensure that:
 - a. It does not disclose PHI to another department, division, or unit of the City, unless HIPAA would allow such disclosure to a legally separate entity. See [Chapter 5, "Permitted Uses and Disclosures."](#)
 - b. Each unit's electronic PHI is maintained separately and access is limited to that unit's workforce (except for permitted disclosures as discussed in [Chapter 5](#)).
 - c. Where possible, staff and office space are physically separated between covered and non-covered functions.
 - d. If a person performs duties for both a Covered Unit and another City department, division, or unit, he or she cannot use or disclose PHI created or received in the course of working for the Covered Unit for his or her other job duties (except for disclosures that would be permitted under this Manual if the two departments were separate legal entities).

D. References: 45 CFR § 164.105

TABLE 3.1: UNITS DESIGNATED AS PART OF THE CITY HEALTH CARE COMPONENT

	COVERED UNIT	HIPAA COVERED FUNCTION
Covered Units	Ambulatory Health Services (AHS)	Health care provider
	Public Health Laboratory (PHL)	Health care provider
	STD Control Program (STDCP)	Health care provider
	Philadelphia Nursing Home (PNH)	Health care provider
	Emergency Medical Services (EMS)	Health care provider
	Office of Behavioral Health and Intellectual disAbility Services (DBHIDS)	Health plan (administers Health Choices program)
	Health and Welfare Benefits (GHP)	Health plan (administers employee group health plan)
	SUPPORT UNIT	SUPPORT SERVICE OR FUNCTION
Support Units	Records Department (Records)	Stores records on behalf of Covered Units
	Office of Innovation and Technology (OIT)	Provides security and support for information systems containing electronic PHI
	Law Department (Law)	Reviews legal requests for records, investigates incidents, and handles medical malpractice claims against clinicians
	Risk Management Division (Risk)	Reviews cases that may require reviewing PHI
	Finance Department (Finance)	Reviews requests for adjustments or write-offs of unpaid invoices sent to EMS patients
	Fire Department (Fire)	Processes requests for access to EMS health records
	Data Management Office (DMO)	Aggregates and de-identifies data from Covered Units
	Riverview Home (Riverview)	Assesses patients' eligibility for health insurance for AHS
	Streets Department (Streets)	Disposes of equipment, hard drives from computers and copiers, and other devices that may include electronic PHI

RECOGNIZING WHAT INFORMATION IS PROTECTED

3.2 DEFINING PROTECTED HEALTH INFORMATION AND DESIGNATED RECORDS SETS

A. Purpose

1. Protected health information or “PHI” is health information subject to protection under the HIPAA Rules. **Protected health information** includes information transmitted or maintained in any form or medium by a covered entity or a business associate on its behalf, that:
 - a. Was created or received by or on behalf of a health care provider, health plan, employer, or health care clearinghouse;
 - b. Relates to the physical or mental health or condition of an individual, the provision of health care to an individual, or the payment for the provision of health care to an individual; AND
 - c. Identifies the individual or might reasonably be used to identify the individual.

PHI excludes (1) education records covered by the Family Educational Right and Privacy Act (FERPA); (2) records described at 20 U.S.C. 1232g(a)(4)(B)(iv); (3) employment records held by a covered entity in its role as employer; and (4) information related to individuals who have been deceased for more than 50 years.

2. A patient's medical record and payment history are common examples of PHI, but PHI also includes less obvious information such as demographic details (for example, name, address, or date of birth) and genetic characteristics (for example, genetic testing, disorders, or predisposition to diseases). PHI even includes the fact that an individual has received services from a particular health care provider or is a member of a specific health plan.
3. HIPAA uses the term “**Designated Record Set**” to identify documentation that contains PHI and is used to make health care decisions about an individual. Individuals have the right to inspect, amend, and obtain copies of PHI contained within a designated record set (but not, for example, business records, accreditation reviews, or other administrative records).

B. Policy

1. **City PHI** includes any PHI that is transmitted or maintained by a Covered Unit, or by a Support Unit or business associate on behalf of a Covered Unit.
 - a. When a Covered Unit (or other covered entity) discloses PHI to another department or person who will perform a function, activity or service listed in the definition of “business associate” (see [Section 5.6](#)) for or on behalf of the disclosing party, such information is essentially borrowed and remains the PHI of the disclosing party (subject to the confidentiality requirements of the BAA or MOU).
 - b. When a Covered Unit (or other covered entity) discloses PHI as authorized by the individual, for treatment, or for another permitted purpose described in [Sections 5.4, 5.7, 5.8, or 5.10](#), such information ceases being the PHI of the disclosing party and is subject to the confidentiality rules of the receiving party.
2. Each Covered Unit must **designate in writing its Designated Record Set(s)**, as follows:
 - a. Covered Units that are health care providers (AHS, STDCP, EMS, PHL, and PNH) must include their medical and billing records and any other records used to make decisions about individuals.
 - b. Covered Units that are health plans (DBHIDS and GHP) must include their enrollment, payment, claims adjudication, and case or medical management record systems, and any other records used to make decisions about individuals.
 - c. As used in this Section, “records” include any item, collection, or grouping of information that includes PHI and is maintained, collected, used, or disseminated by or for a Covered Unit. Records may be in paper, electronic, digital, audio, or any other format. See [Table 3.2](#) for examples of records that are included in or excluded from the designated record set(s).

RECOGNIZING WHAT INFORMATION IS PROTECTED

C. Procedures

1. Each Covered Unit is responsible for identifying and managing its own PHI. Each Covered Unit should be prepared to provide an inventory of the types and locations of PHI it maintains (indicating programs, information systems and physical locations) whenever such information is requested by the City HIPAA Privacy Officer ("CHPO") or City HIPAA Security Officer ("CHSO").
2. Each Support Unit is responsible for recognizing what PHI it has obtained from, or created on behalf of, a Covered Unit and ensuring that all such PHI is used, disclosed, and protected in a way that meets the requirements of its MOU with the Covered Unit. A Support Unit is expected to keep any PHI it has obtained from or on behalf of a Covered Unit separate from its own data.
3. Any questions about whether information is PHI should be directed to the CHPO.
4. Each Covered Unit will maintain an index identifying those records included in its Designated Record Set(s). The index must be in writing, maintained as part of the Covered Unit's HIPAA Documentation, accessible to its workforce, and provided to the CHPO upon request.
5. When responding to requests from individuals to access, amend, restrict, or acquire an accounting of disclosures relating to their records, the Covered Unit will reference its Designated Record Set index to ensure all databases and systems have been searched and the response is complete.
6. When engaging a Support Unit or business associate to provide services or perform functions on its behalf, a Covered Unit must decide whether the PHI created, collected, or used by the Support Unit or business associate will be part of a Designated Record Set. If so, the Covered Unit must provide the Support Unit or business associate with adequate instructions on how to track and work with the records so that the Covered Unit can meet its obligations outlined in [Chapter 8, "Honoring an Individual's Rights."](#)

D. References: 45 CFR §§ 160.103, 164.501, 164.524

TABLE 3.2: EXAMPLES OF INFORMATION IN DESIGNATED RECORD SETS

INCLUDED IN DESIGNATED RECORD SETS	EXCLUDED FROM DESIGNATED RECORD SETS
• Clinical records (history & physical, orders, results, progress notes, assessments, consult reports, vitals) • Clinical source data (x-rays, imaging and radiology reports, pathology slides, etc.) • External records used to make health care decisions (i.e., from another provider) • Authorizations and consent forms • Billing records • Claim submissions and supporting medical documentation, referrals, and Authorizations • Eligibility determinations • Explanations of benefits or coverage • Case management records	• Quality assessment reports • Credentialing or accreditation records • Internal grievance reports • Incident reports or investigations • Information in employee records • Financial reports • Internal compliance and audit reports • Administrative records • Public health records and statistical data • Attorney-client privileged documents • Departmental policies and procedures • Research records not used to make treatment decisions

RECOGNIZING WHAT INFORMATION IS PROTECTED

3.3 HIGHLY CONFIDENTIAL INFORMATION

A. Purpose

1. The HIPAA Rules provide a privacy and security foundation for protected health information ("PHI"). Other federal and state laws contain additional protections for specific types of highly confidential health information, such as HIV-related information, substance abuse treatment records, mental health treatment records, and clinical laboratory results ("**Highly Confidential Information**").
2. In addition, licensed professionals and facilities may be subject to greater confidentiality obligations based on the standards of their profession, licensure, or accreditation.
3. This policy provides guidance regarding PHI that is subject to additional protections or must be treated differently than other types of PHI.
4. City departments maintain many other types of health information that are not subject to HIPAA (non-PHI) but are confidential under other laws, for example: communicable disease reports, surveillance data, vital statistics, cancer registries, child protective services records, and medical examiner files. Those requirements are not addressed in this policy.

B. Policy

1. The City will follow HIPAA and all federal or state laws providing privacy protections for PHI and Highly Confidential Information.
 - a. All applicable laws will be followed to the extent their requirements do not directly contradict each other.
 - b. If state law is contrary to HIPAA, HIPAA will be followed except in cases where state law:
 - i. provides greater privacy protections or privacy rights with respect to PHI,
 - ii. provides for the reporting of disease or injury, child abuse, birth, or death, or for public health surveillance, investigation, or intervention, or
 - iii. requires certain health plan reporting, such as for management or financial audits.
 - c. When multiple laws are applicable and their confidentiality requirements seem to be contrary, the City HIPAA Privacy Officer ("CHPO") will determine which requirements control.
2. As a general rule, Highly Confidential Information will not be disclosed without the individual's written consent specifically identifying the type of Highly Confidential Information to be disclosed. There are some exceptions, for example:
 - a. Disclosures to other health care providers, when knowledge of the Highly Confidential Information is necessary to provide emergency treatment to the patient, and
 - b. PHI required to be disclosed by a court order (see [Section 5.8](#)).
3. Each workforce member is expected to recognize the types of Highly Confidential Information listed in [Table 3.3](#) below and be aware of the confidentiality requirements applicable under his or her licensing and professional standards.

C. Procedures

1. Whenever using or disclosing PHI, workforce members must assess whether any Highly Confidential Information is included in the records and follow Departmental protocols appropriate to that type of information (or, if no protocols exist, seek guidance from the Law Department).
2. When obtaining an individual's written consent to disclose Highly Confidential Information, an approved City or Departmental form should be used to ensure the consent contains all the elements required by HIPAA and other applicable federal or state law (see [Section 5.3](#)).
3. When disclosing HIV-Related Information, Substance Abuse Treatment Records, or Mental Health Treatment Records, the following notice must be provided to the recipient:

RECOGNIZING WHAT INFORMATION IS PROTECTED

“This information has been disclosed to you from records whose confidentiality is protected by Pennsylvania law (35 P.S. § 7607, 50 P.S. § 7111) and/or federal rules (42 CFR Part 2). These rules prohibit you from making any further disclosure of this information unless further disclosure is expressly permitted by the written consent of the person to whom it pertains or is otherwise authorized by the applicable law. A general authorization for the release of medical or other information is NOT sufficient for this purpose. The federal rules restrict any use of the information to criminally investigate or prosecute any alcohol or drug abuse patient.”

4. Any questions about what information is Highly Confidential Information or whether Highly Confidential Information can be used or disclosed should be referred to the Law Department.

D. References: listed within Table 3.3

TABLE 3.3: HIGHLY CONFIDENTIAL INFORMATION

HIV-Related Information: State law protects HIV-related information, including whether an individual has been the subject of an HIV-related test, or has HIV, HIV-related illness or AIDS; or any information which could identify an individual as having one of these conditions. (35 P.S. § 7607)	These records can only be disclosed: (1) to the patient or with the patient's written consent; (2) to the physician who ordered the test and other clinicians who need to know the condition or test result to treat the patient; (3) to an insurer as needed to pay claims for HIV-related services; (4) as required by a court order; (5) as authorized by the Disease Prevention and Control Law and Vital Statistics Law; or (6) in limited other circumstances (consult Law).
Substance Abuse Treatment Records: Federal and state laws protect records relating to substance abuse treatment. These laws apply to records created or maintained by programs that provide alcohol or drug abuse diagnosis, treatment or referral for treatment. (42 USCS § 290dd-2; 71 P.S. § 1690.108)	<i>With the patient's written consent</i>, records can only be disclosed: (1) to medical personnel exclusively to diagnose and treat the patient; or (2) to government or other officials exclusively to obtain benefits due the patient as a result of his or her substance abuse or dependence. <i>Without patient consent</i>, records can only be disclosed: (1) to medical authorities providing medical care in emergency medical situations where the patient's life is in immediate jeopardy; or (2) as required by a court order upon a showing of good cause.
Mental Health Treatment Records: State law protects information related to mental health treatment, specifically records of patients receiving mental health treatment on an involuntary basis or a voluntary inpatient basis. (50 P.S. § 7111; 55 Pa. Code §§ 5100.31-39)	Specific portions or summaries of the record can be disclosed: (1) with the patient's written consent, (2) to those engaged in providing treatment to the person, (3) to a court or review officer in commitment proceedings, (4) in response to an emergency medical situation when necessary to prevent serious risk of bodily harm or death, (5) as required by a court order, or (6) in limited other circumstances (consult Law).
Psychotherapy Notes: HIPAA specially protects psychotherapy notes, which are personal notes of a mental health professional reflecting conversations with a client. (45 CFR § 164.508)	Psychotherapy notes are kept separate from the rest of the medical record and are typically not useful for treatment, payment, or operational purposes (other than by the author). Psychotherapy notes can only be disclosed with the patient's written Authorization, with limited exceptions (consult the CHPO).
Clinical Laboratory Results: Federal and state laws protect patient records and reports of clinical laboratory test results. (42 CFR § 493.1231; 28 Pa. Code §§ 5.47, 5.53)	Clinical laboratory reports and patient records can only be disclosed: (1) to the person who submitted the specimen or requested the analysis, or (2) as otherwise required by law (such as mandatory disease reporting).
Medical Records: State licensing laws protect medical records arising out of a physician's care of a patient, including pertinent clinical information, diagnoses, findings, laboratory results and other diagnostic, corrective or therapeutic procedures, including prescription drug orders. (49 Pa. Code § 25.213)	Medical records can only be disclosed: (1) with the patient's written consent, (2) as required by a court order, (3) for insurance audits related to health care provided to the patient, (4) to defend against malpractice allegations, or (5) to comply with other federal or state health care laws.
Reports of Abuse (Children or Older Adults): State laws protect information contained in reports of abuse sent to local protective service agencies, the PA Department of Human Services, and law enforcement agencies. (23 Pa.C.S. §§ 6301-86; 55 Pa. Code §§ 3490.91-95; 35 P.S. §10210.505)	Reports of abuse received by City workforce members from a protective services agency remain subject to the confidentiality requirements applicable to the agency that collected the report. Consult the Law Department for specific requirements.

RECOGNIZING WHAT INFORMATION IS PROTECTED

3.4 DE-IDENTIFIED DATA AND LIMITED DATA SETS

A. Purpose

1. Once protected health information (PHI) has been de-identified, it is no longer PHI, and the restrictions and requirements of federal and state privacy laws no longer apply. However, if a re-identification code is added to the data, certain privacy and security rules apply to the code.
2. HIPAA authorizes two methods of de-identification: (a) use of statistical methods proven to render information not individually identifiable, and (b) deletion of 18 specified identifiers.
3. A limited data set may be used in certain situations when de-identified data is not sufficient for research, public health, or health care operations purposes, pursuant to a data use agreement. Since it is only partially de-identified, a limited data set is still considered PHI and remains subject to all HIPAA protections.

B. Policy

1. Unless an exception is granted by the City HIPAA Privacy Officer ("CHPO"), the only **approved method for de-identification** of City PHI is removal of all 18 identifiers as listed in [Table 3.4](#).
2. A Covered or Support Unit may assign a code or key to allow information de-identified under this section to be re-identified by the Covered or Support Unit, provided that:
 - a. The code or key is not derived from or related to information about the individual and is not otherwise capable of being translated so as to identify the individual; and
 - b. The Covered or Support Unit does not use or disclose the code or key for any other purpose, and does not disclose the mechanism for re-identification.
3. A **limited data set** may be created for a research, public health, or health care operations purpose when de-identified data is not sufficient. Before disclosing a limited data set, the disclosing unit's Privacy Officer/Liaison and the Law Department must approve the data elements to be disclosed and the data license agreement with the recipient.

C. Procedures

1. De-identification must occur internally prior to disclosing data outside of the originating unit, except to a Support Unit or business associate who is authorized to perform the de-identification on behalf of the Covered Unit (as authorized under an appropriate MOU or BAA, see [Sections 3.1](#) and [5.6](#)).
2. A Covered Unit's Privacy Officer may either: (a) designate certain workforce members who have received training and are approved to de-identify their Covered Unit's PHI, or (b) review and approve de-identified data sets on a case-by-case basis to ensure the data has been appropriately de-identified.
3. If a code or key will be used to re-identify the data, the Covered Unit's Privacy Officer must approve the following:
 - a. method for creating the key (demonstrating that it will not be derived from identifiers),
 - b. procedures for safeguarding the key and destroying it when no longer needed,
 - c. description of who will have access to the key and for what purposes, and
 - d. description of how any re-identified information will be protected.
4. When seeking to disclose a limited data set for a research, public health, or health care operations purpose, workforce members should contact the Covered Unit's Privacy Officer to approve the data elements to be disclosed and the Law Department to prepare and execute a data use agreement with the recipient that meets HIPAA requirements (45 CFR § 164.514(e)).

RECOGNIZING WHAT INFORMATION IS PROTECTED

D. References: 45 CFR §§ 164.502(d), 164.514

TABLE 3.4: DE-IDENTIFICATION PROCEDURE

STEP 1	REMOVE THESE DATA ELEMENTS: - Names; - All geographic subdivisions smaller than a State, including street address, city, county, precinct, zip code, and their equivalent geocodes, except for the initial three digits of a zip code if, according to the current publicly available data from the Bureau of the Census: - The geographic unit formed by combining all zip codes with the same three initial digits contains more than 20,000 people; and - The initial three digits of a zip code for all such geographic units containing 20,000 or fewer people is changed to 000. - Currently, 036, 059, 063, 102, 203, 556, 592, 790, 821, 823, 830, 831, 878, 879, 884, 890, and 893 are all recorded as "000". - All elements of dates (except year) for dates directly related to an individual, including birth date, admission date, discharge date, date of death; and all ages over 89 and all elements of dates (including year) indicative of such age, except if aggregated into a single category of age 90+; - Telephone numbers; - Fax numbers; - Electronic mail addresses; - Social security numbers; - Medical record numbers; - Health plan beneficiary numbers; - Account numbers; - Certificate/license numbers; - Vehicle identifiers and serial numbers, including license plate numbers; - Device identifiers and serial numbers; - Web Universal Resource Locators (URLs); - Internet Protocol (IP) address numbers; - Biometric identifiers, including finger and voice prints; - Full face photographic images and any comparable images; and - Any other unique identifying number, characteristic, or code (for example, "Mayor of Philadelphia"). Note: A re-identification code or key as described in Section 3.4(c)(3) may be included in the data.
	CONFIRM THAT, TO YOUR KNOWLEDGE: the remaining information cannot be used alone or in combination with other information to identify an individual who is a subject of the information. For example, an individual with an unusual wound reported in a local newspaper might be identifiable if his records were released, even after the above data elements have been removed.

GROUND RULES FOR WORKING WITH PHI

4.0 Ground Rules for Working with PHI

4.1 THE MINIMUM NECESSARY STANDARD

A. Policy

1. Workforce members may use, disclose, and request only the minimum amount of PHI necessary to accomplish a permitted purpose. Minimum necessary means that the smallest amount of PHI is available to the fewest people needed to get the job done.
2. The minimum necessary standard applies in three circumstances:
 - a. When using PHI internally;
 - b. When disclosing PHI to anyone outside of the Covered or Support Unit; and
 - c. When requesting PHI from any other Covered or Support Unit, or another covered entity.
3. Departmental management will authorize role-based access to PHI, limited to what is needed based on the scope and responsibilities of a workforce member's position. Role-based access protocols apply whether the access controls are built in to the information systems or whether the access is to PHI in any other form.
4. A workforce member may access only the PHI that is legitimately needed to carry out his or her job responsibilities. For example, a workforce member may not access an entire medical record unless the entire record is specifically required to accomplish his or her job. Any workforce member who accesses PHI for purposes not consistent with their access privileges or not necessary to accomplish their duties is subject to disciplinary action up to and including termination.
5. Before disclosing or requesting PHI, workforce members will review the request to ensure it meets the minimum necessary standard using the criteria outlined below.

B. Procedures

1. Each Covered and Support Unit will identify, document, and enforce the **role-based access** needed for each job description. Role-based access protocols should:
 - a. List people or classes of people who need access to PHI to carry out their duties;
 - b. Specify the categories of PHI to which access is needed, including any conditions that may be relevant to such access;
 - c. Describe processes for assigning, periodically reviewing, modifying, enforcing, and terminating access privileges;
 - d. Be consistent with City and departmental HIPAA security policies and procedures; and
 - e. Be available upon request for review and be maintained as part of the Covered or and Support Unit's HIPAA Documentation (see [Section 9.5](#)).
2. Departmental management will ensure each workforce member understands his or her access privileges, which job functions and duties require access to PHI, and the types of PHI he or she is permitted to access or use.
3. When making disclosures or requesting PHI on a **routine and recurring basis**, workforce members should follow the guidance in [Table 4.1](#) below and any additional departmental protocols identifying the minimum necessary PHI needed for routine disclosures or requests. [Table 4.1](#) also lists uses and disclosures that are **exceptions** to the minimum necessary standard.
4. Any other types of disclosures or requests for PHI must be individually reviewed to verify that the PHI disclosed or requested is the minimum necessary to accomplish the intended purpose. Workforce members should use the following criteria to evaluate a **non-routine disclosure** or request:
 - a. Is the purpose specifically stated and the requested PHI clearly identified?
 - b. Is the requested PHI directly related to the intended purpose?

GROUND RULES FOR WORKING WITH PHI

- c. Would less PHI or de-identified information be sufficient for this purpose?
- d. Could the disclosure negatively impact the Individual whose PHI is being disclosed?
- e. Is any Highly Confidential Information being requested? If so, refer to [Section 3.3](#).
- f. If the entire medical record is requested, is there adequate justification?
- g. Have all required supporting documents been provided? (For example, confirming the requestor's identity or authority to access the PHI, or a personal representative's authority to act in that capacity.)

C. References: 45 CFR § 164.502(b); § 164.514(d)

TABLE 4.1: MINIMUM NECESSARY REFERENCE GUIDE

RECIPIENT	PURPOSE	WHAT TO DISCLOSE
Health care provider*	For treatment	May disclose whatever the health care provider requests
Individual (the subject of the PHI)*	Any purpose	Must disclose what the Individual requests (with limited exceptions as described in Section 8.2)
Person named in an Authorization*	As stated in the Authorization	May disclose the PHI identified in the Authorization
Secretary of DHHS*	HIPAA compliance and enforcement	Must disclose the PHI requested by DHHS
Person specified by law or court order*	As required by law	May disclose whatever PHI is required for the disclosing unit to comply with the relevant law or court order
Public official (police, national security, public health authorities)**	Purposes permitted under 45 CFR § 164.512	May disclose the PHI requested, if the official represents that it is the minimum necessary for the stated purpose
Another HIPAA covered provider or health plan**	For payment or health care operations	May disclose the PHI requested (the other covered entity may only request the minimum necessary)
Researcher**	For approved research	May disclose the PHI indicated in the IRB approved Waiver of Authorization (see Section 5.9)

* Exception to the minimum necessary standard.

** If reasonable under the circumstances, may rely on the request as representing the minimum necessary PHI.

GROUND RULES FOR WORKING WITH PHI

4.2 VERIFYING THE RECIPIENT

A. Purpose

1. The Privacy Rule requires covered entities to verify the identity and authority of a person requesting PHI, if the person is not known to the covered entity.
2. The purpose of verification is to prevent PHI from inadvertently being given to the wrong person. While strong verification procedures are encouraged, they cannot be so burdensome that they prevent an individual from accessing his or her own health record.

B. Policy

1. When making disclosures of PHI in accordance with these policies and procedures, workforce members must take reasonable steps to verify: (a) the **identity** of the person to whom the PHI is disclosed; and (b) that person's **authority** to receive the PHI.
2. The procedures below establish standards for verifying the identity and authority for requests made by the individual, a parent seeking access to the PHI of his or her minor child, a personal representative, a public official seeking access, and other third parties. Reasonable verification steps may vary depending on the circumstances. Departmental protocols may supplement these procedures to address specific types of disclosures or information relevant to that unit.
3. If a requestor is known to the workforce member who is authorized to make the requested disclosure, the workforce member may waive the identify check. When a workforce member makes recurring disclosures to the same recipient for the same purpose (for example, when working with a business associate on a project that requires repeated disclosures), ongoing identify and authority checks are not necessary.

C. Procedures

1. *Identity Check.* To verify the **identity** of any person requesting to receive PHI, request proof of identity matching the name of the individual whose records are requested or the person who is authorized to request records. Examples of acceptable methods for verifying identity include:
 - a. In Person Requests: valid driver's license, passport, employee or military identification, or other official photo identification. If the requestor is a public official or law enforcement, request an agency badge or other official credentials.
 - b. Written Requests: Match between signature on request and signature on file; provision of identifying information that matches individual's record (name, address, dates of service, name of provider, etc); request on official letterhead or received from an official email address identifying an organization or government agency that is authorized to receive the PHI.
 - c. Verbal Requests: Confirmation of identifying data, such as full name, date and place of birth, or such other personal information unique to the individual; verification by calling back the individual's number on file. Workforce members should be very cautious when communicating PHI by telephone, limiting verbal disclosures to the individual or his/her personal representative, authorized recipients who are known to the workforce member, or health care providers (or disaster relief personnel) in emergency situations.
2. *Authority Check.* To verify the **authority** of any person requesting access to PHI, request proof including the following:
 - a. Request by Parent or Guardian of a Minor Child: a copy of a birth certificate, court order, guardianship documents, or other evidence of parental relationship with minor child.
 - b. Request by Personal Representative: a copy of a valid power of attorney, letters testamentary, appointment as executor, or other documents listed in [Table 8.1](#).
 - c. Request by Public Official: a written statement of the legal authority under which the information is requested, or an oral statement if a written statement would be impracticable; written evidence that an individual is acting under government authority (such as a contract or purchase order that verifies that a

GROUND RULES FOR WORKING WITH PHI

private citizen is acting as an agent of a government agency in requesting the PHI). If the request is made pursuant to legal process, warrant, subpoena, order, or other legal process issued by a grand jury or a judicial or administrative tribunal, follow the procedure in [Section 5.8](#).

- d. Request by Health Care Provider Treating the Individual: The requesting entity should provide the provider's name, facility name, location, and the telephone number.
 - e. Request by Other Third Parties: A copy of a valid Authorization naming that person.
3. A copy of the documents verifying the requestor's identification and authority should be maintained in the record of the individual whose information was requested. Disclosures must be documented in accordance with the procedure for "Tracking Disclosures" ([Section 4.3](#)).
 4. Before releasing PHI to anyone other than the individual who is the subject of the information, workforce members should check that there are no restrictions (granted pursuant to [Section 8.5](#)).
 5. Workforce members may act on a good faith belief of identity without specific verification when necessary to avert a serious threat to the health or safety of the patient, another person or the public, under the specific circumstances described in [Section 5.10\(B\)\(1\)\(d\)](#).
 6. Workforce members should exercise their professional judgment in applying these verification standards, and seek guidance as needed from their unit's Privacy Officer/Liaison, or the City HIPAA Privacy Officer.

D. References: 45 CFR § 164.514(h)

GROUND RULES FOR WORKING WITH PHI

4.3 TRACKING DISCLOSURES

A. Purpose

1. In general, individuals have the right to know who has received their protected health information (PHI) when they didn't authorize the disclosure or it was made for reasons other than treatment, payment, health care operations. HIPAA requires covered entities to provide individuals with an accounting of disclosures upon request, as further described in [Section 8.4](#).
2. For this reason, covered entities must maintain a record of all disclosures of PHI unless the disclosure fits within an exception to the accounting requirement.

B. Policy

1. Covered Units will maintain records of all disclosures required to be included in an accounting of disclosures to an individual (see [Section 8.4](#)).
2. The following categories of disclosures are **EXCLUDED** from the accounting:
 - a. For purposes of treatment, payment, or health care operations;
 - b. Pursuant to the individual's Authorization;
 - c. To the individual or the individual's personal representative;
 - d. To persons involved in the individual's care or payment for care, including notification in disaster relief situations (see [Section 5.4](#));
 - e. For national security or intelligence purposes;
 - f. To correctional institutions or law enforcement officials regarding inmates or individuals in lawful custody;
 - g. Incidental to another acceptable disclosure (see [Section 6.0](#)); or
 - h. As part of a limited data set.
3. If a Covered Unit authorizes a Support Unit or business associate to make disclosures that would be subject to the accounting requirement if made by the Covered Unit, the Support Unit or business associate must also meet the tracking requirements in this Section.

C. Procedures

1. Each Covered Unit must develop a HIPAA disclosure tracking system that allows it to account for all disclosures subject to the accounting requirement (as listed in [Table 4.3](#)).
2. The tracking system must capture at least the following for each disclosure:
 - a. Date of disclosure;
 - b. Recipient's name and, if known, recipient's address;
 - c. Description (what PHI was disclosed);
 - d. Purpose (why PHI was disclosed); and
 - e. Name of individual(s) whose PHI was disclosed.
3. If the Covered Unit makes routine or repeated disclosures to the same recipient for a single purpose, the Covered Unit may record the first and last date of the disclosures, and frequency or number of disclosures made during that time period, rather than listing all dates on which a disclosure was made.
4. A Covered Unit may maintain a central list of disclosures impacting all records rather than documenting the disclosure in each individual's record. For example, if the City health centers disclose information about all patients to a public health authority for a surveillance activity, AHS may choose to list this disclosure in a central log rather than each patient's file.

GROUND RULES FOR WORKING WITH PHI

D. References: 45 CFR § 164.528

TABLE 4.3: DISCLOSURE TRACKING REQUIREMENTS

Type of Disclosure	Examples	HIPAA §	Policy §	Subject to Accounting?	
				Yes	No
To the individual or the individual's authorized personal representative	An individual's request to access or view their own health records	164.502 164.524 164.528	<u>8.2</u> <u>8.1</u>		☒
For treatment, payment, or health care operations	Treatment: from one health care provider to another for their own treatment activities Payment: from a health care provider to a payer for payment activities Operations: quality improvement or fraud and abuse detection	164.506	<u>5.5</u>		☒
Incident to an acceptable use or disclosure	Briefly overhearing a conversation between a doctor and a nurse Seeing another patient's name on a sign-in sheet	164.502	<u>6.0</u>		☒
As authorized by the individual	Any disclosure made pursuant to a signed Authorization	164.502 164.508	<u>5.3</u>		☒
To persons (family, friends) involved in the individual's care or payment for care, or disaster relief agencies in emergency situations	The individual's location, general condition, and death	164.510	<u>5.4</u>		☒
To DHHS for HIPAA compliance	In response to an Individual's complaint to DHHS or an audit conducted by DHHS	164.502	<u>5.2</u>	☒	
To business associates	To a lawyer or accountant for the provision of professional services	164.502 164.504	<u>5.6</u>	☒	
By whistleblowers	Workforce member to a health oversight agency to investigate a failure to meet professional standards	164.502(j)(1)	<u>5.10</u>	☒	
For public health activities	Immunizations Infectious/Communicable Disease Reporting (e.g., HIV, STD, TB) Vital Statistics Lead poisoning Animal Bite Reporting	164.512(b)	<u>5.7</u>	☒	
About victims of abuse, neglect, or domestic violence	Disclosures to social service or protective service agencies regarding: Domestic violence Elder Abuse Child abuse	164.512(c) 164.512(b)(1)(ii)	<u>5.7</u>	☒	

GROUND RULES FOR WORKING WITH PHI

For health oversight activities	Audits (e.g., Center for Medicare and Medicaid Services) Inspections (e.g., Pennsylvania Department of Environmental Protection) Oversight Reviews (e.g., Pennsylvania Department of Health)	164.512(d)	<u>5.10</u>	☒	
For judicial and administrative proceedings	Court orders Subpoenas Summons or investigative demands	164.512(e) 164.512(f)(1)(ii)	<u>5.8</u>	☒	
For law enforcement purposes	To assist in identifying a suspect, fugitive, material witness, or missing person Information regarding the victim or suspected victim of a crime Disclosure regarding a crime on the premises	164.512(f)(2)-(6)	<u>5.10</u>	☒	
To coroners, medical examiners, and funeral directors	Identifying a diseased person or determining a cause of death Disclosure to funeral directors to prepare for a deceased's funeral.	164.512(g)	<u>5.7</u>	☒	
For organ and tissue donation	Communications to coordinate organ and tissue donations between providers who treated deceased individual and organ procurement organizations.	164.512(h)	<u>5.10</u>	☒	
For research that does not require the subject's Authorization	Research that receives a waiver of Authorization by the IRB Research involving the health information of decedents	164.512(i)	<u>5.9</u>	☒	
To avert a serious threat to health or safety	Release of medical records to a child protective services agency in case of an emergency	164.512(j)	<u>5.10</u>	☒	
For national security and intelligence activities	Disclosures to agencies such as the NSA, FBI, and CIA	164.512(k)(2)	<u>5.10</u>		☒
To correctional institutions or law enforcement officials who have custody of an individual	Disclosure of PHI of a person in a correctional institution to allow the correctional institution to provide healthcare.	164.512(k)(5)	<u>5.10</u>		☒
Between government programs providing public benefits	Eligibility determination between Medicaid program and food stamp programs	164.512(k)(6)	<u>5.10</u>	☒	
Otherwise required/permitted by law	Workers comp	164.512(a)&(l)	<u>5.7</u> <u>5.10</u>	☒	
As part of a limited data set	Health information that excludes specific direct identifiers of the patient	164.514(e)	<u>3.4</u>		☒
Breach or mistake	Fax sent to wrong number Information mailed to wrong address Verbal disclosure to unauthorized 3rd party Lost or stolen records		<u>7.0</u>	☒	

PERMITTED USES AND DISCLOSURES

5.0 Permitted Uses and Disclosures

5.1 PERMITTED USES

A. Purpose

1. In order to protect an individual's right to privacy, HIPAA limits the purposes for which a covered entity may use the protected health information (PHI) it collects or maintains.
2. **"Use"** refers to internal activities that require sharing, application, review, or analysis of PHI within the entity that maintains the PHI. For example, a use occurs when a clinician reviews a patient record and discusses the patient's condition with others on the patient care team. Or when an EMS supervisor reviews incident reports to ensure the medics under his or her supervision are providing high quality care meeting the expected standards.
3. Due to the City's hybrid status (see [Section 3.1](#)), any activity that requires PHI to be shared from one Covered or Support Unit to another City unit is considered a disclosure rather than a use of PHI. For example, when an Ambulatory Health Services physician reports a communicable disease to the Division of Disease Control, this is considered a disclosure even though both units are within the Department of Public Health.

B. Policy

1. In general, workforce members may use PHI for any purpose that the individual who is the subject of the information authorizes in writing.
2. Support Units receive PHI from, or create or maintain PHI on behalf of, Covered Units for specific purposes. For this reason, workforce members of Support Units may only use the Covered Unit's PHI **for the purposes permitted in a written agreement (MOU)** between those units. For example, when the Records Department stores records for the Public Health Laboratory, the Records Department is a Support Unit of the Public Health Laboratory and cannot use the laboratory records for anything other than the purposes permitted by the Public Health Laboratory.
3. Covered Units may use PHI without the individual's written Authorization for a number of additional purposes relating to the provision of healthcare, effective operation of the healthcare system, and other important public benefits or national priorities, including:
 - a. To provide treatment;
 - b. To pay or obtain payment for health care services;
 - c. For the Covered Unit's own health care operations (see [Sections 2.1](#) and [5.5](#) for details about what activities are "health care operations");
 - d. As required by law;
 - e. For public health activities (if the Covered Unit is also a public health authority);
 - f. For research, subject to the requirements of an approved Waiver of Authorization; and
 - g. To create a limited data set or to de-identify data (see [Section 3.4](#)).
4. Special types of information.
 - a. Genetic information may not be used for underwriting purposes.
 - b. Psychotherapy notes may only be used for treatment purposes by the author of the notes, and in limited additional situations (consult the City HIPAA Privacy Officer ("CHPO")).

C. Procedures

1. When using PHI, workforce members are responsible for taking these steps:
 - a. Understanding what PHI they are using for their job and why they are permitted to do so;

PERMITTED USES AND DISCLOSURES

- b. Identifying whether any additional use restrictions apply (for example, for special types of information (see [Section 3.3](#)) or as requested by the individual (see [Section 8.5](#)));
 - c. Using the PHI only as is consistent with the permitted use, any additional restrictions, and the minimum necessary standard (see [Section 4.1](#)); and
 - d. Reporting potential misuse of PHI (see [Section 7.0](#)).
2. When in doubt, workforce members should contact a supervisor, their unit's Privacy Officer/Liaison, or the CHPO for guidance.
3. Support Units will ensure their workforce members understand the business function or service they are performing for a Covered Unit and what PHI is being received, created, or maintained for that purpose. Support Units will develop protocols as needed to ensure their use of PHI is consistent with their written agreement with the Covered Unit.

D. **References:** 45 CFR §§ 164.502, 164.508(a)(2)

TABLE 5.1: EXAMPLES OF PERMITTED USES

UNIT	PURPOSE	EXAMPLES
STDP, AHS, PHL, EMS	Treatment	Health care providers involved in the individual's care may review the individual's record and consult with other team members to provide treatment or coordinate health care services to the individual.
DBHIDS, GHP	Treatment	No permitted uses for treatment; these units are functioning as health plans and do not provide treatment.
STDP, AHS, PHL, EMS	Payment	Billing staff may review PHI to prepare and submit reimbursement claims to a health plan.
DBHIDS, GHP	Payment	Workforce members may review an individual's record to determine eligibility or coverage under a health plan or to adjudicate claims.
Any Covered Unit	Operations	Appropriate personnel may review records to ensure good quality care is being provided, that claims are being paid appropriately, and that eligibility requirements are satisfied.
DBHIDS, GHP	Operations	Health plans may use PHI for underwriting and other activities relating to the creation, renewal, or replacement of an insurance or benefits policy; except that no genetic information can be used for this purpose.
Any Covered Unit	Required by Law	The Covered Unit's workforce members may review records to prepare legally-required reports or comply with other legal requirements (consult with Law Department).
Any Covered Unit	Research	Researchers may use the PHI indicated in the IRB approved Waiver of Authorization (see Section 5.9) in a manner consistent with the approved research protocols.

PERMITTED USES AND DISCLOSURES

5.2 PERMITTED DISCLOSURES

A. Purpose

1. A “**disclosure**” occurs when any protected health information (PHI) is accessed by or provided to a person or entity outside of the covered entity that created or is maintaining the PHI.
2. Due to the City’s hybrid status (see [Section 3.1](#)), any activity that requires PHI to be shared from one Covered or Support Unit to another City unit is considered a disclosure of PHI, even though both units are part of the City.
3. This Section provides general procedures for workforce members to follow when disclosing PHI. Specific types of disclosures are addressed in subsequent Sections.
4. Any disclosures outside of those specifically authorized in this Manual, or disclosures made in error (for example, to the wrong recipient), are Incidents that must be reported under [Section 7.0](#).

B. Policy

1. Covered and Support Units will maintain the confidentiality of PHI and only disclose PHI in compliance with HIPAA, other federal or state laws protecting Highly Confidential Information, and any other applicable restrictions or requirements.
2. Permitted Disclosures:
 - a. There are two situations in which **PHI may almost always be disclosed**:
 - i. As authorized in writing by the Individual (see [Section 5.3](#)); and
 - ii. When required by a court order (see [Section 5.8](#)).
 - b. Without obtaining an Authorization or court order, PHI may also be disclosed in compliance with the requirements for each specific type of disclosure outlined in [Sections 5.4-5.10](#).
3. Mandatory Disclosures: There are only two situations in which **PHI is required to be disclosed**:
 - a. To the individual who exercises his or her rights (see [Chapter 8](#)), and
 - b. To DHHS when required for HIPAA compliance purposes.
4. Prohibited Disclosures: In the following situations, **PHI may never be disclosed**:
 - a. Genetic information for underwriting purposes,
 - b. Where the Covered or Support Unit, or its business associate, provides PHI in exchange for money or other benefits that qualify as a “sale of PHI” under HIPAA (consult the CHPO);
 - c. Where the disclosure does not fit within a category of disclosures permitted by HIPAA; or
 - d. Where other applicable laws or restrictions prohibit the disclosure.
5. Support Units may only disclose PHI to the extent permitted in the underlying Memorandum of Understanding (“MOU”) with the Covered Unit for which the Support Unit is providing services.

C. Procedures

1. Before sharing PHI, workforce members must confirm that the purpose of the disclosure is permitted under this Policy Manual and any conditions associated with that purpose are met.
2. When disclosing PHI for a permitted purpose, workforce members should take the following steps:
 - a. Apply the minimum necessary standard ([Section 4.1](#)).
 - b. Verify the recipient’s identity and authority to receive the PHI ([Section 4.2](#)).
 - c. Review the information to ensure Highly Confidential Information has been removed. If Highly Confidential Information must be disclosed, review [Section 3.3](#) and consult with Law.
 - d. Confirm that the disclosure is consistent with the unit’s Notice of Privacy Practices.
 - e. When a Support Unit is disclosing PHI, confirm that the disclosure is permitted under the Support Unit’s MOU with the Covered Unit for which it is providing services.

PERMITTED USES AND DISCLOSURES

- f. Be alert for additional restrictions (such as contractual obligations) limiting disclosure.

D. References: 45 CFR § 164.502

5.3 CONSENT/AUTHORIZATION

A. Purpose

1. Generally, an individual who is able to comprehend and make voluntary, informed decisions about his or her health care may freely authorize particular uses or disclosures of his or her protected health information (PHI). For individuals unable to make their own health care decisions (such as children, deceased individuals, or incapacitated adults), a personal representative may authorize the disclosure on the individual's behalf (see [Section 8.1](#)).
2. Under HIPAA, an **Authorization** is a detailed document that gives covered entities permission to use PHI for specified purposes or to disclose PHI to a third party specified by the individual. Without a valid Authorization, covered entities are limited in how they may use or disclose PHI.
3. State confidentiality laws may also require a patient's written consent to disclose certain types of information (see [Section 3.3](#)). If Highly Confidential Information is disclosed, the consent form must include additional language beyond what is typically found in a HIPAA Authorization.

B. Policy

1. City workforce members will obtain a valid Authorization from the individual or the individual's personal representative before disclosing PHI, unless this HIPAA Policy Manual specifically permits otherwise (see [Sections 5.4-5.10](#)).
2. Any use or disclosure of PHI under the terms of an Authorization must be consistent with the provisions of that Authorization.
3. Individuals may refuse to authorize certain uses or disclosures of their PHI. Covered Units will not condition treatment, payment, enrollment, or benefits eligibility on an individual granting an Authorization, except in limited circumstances:
 - a. A health care provider may condition the provision of research-related treatment on provision of an Authorization for the use or disclosure of PHI for such research;
 - b. A health plan may condition enrollment in the health plan or eligibility for benefits on provision of an Authorization for PHI (except psychotherapy notes) needed for the health plan's eligibility or enrollment determinations relating to the individual or for its underwriting or risk rating determinations; or
 - c. A covered entity may require an Authorization before providing a service, when the sole purpose of the service is to provide PHI to a third party (for example, a second opinion).
4. An individual may revoke an Authorization at any time by written request. A revocation will be effective immediately, but will not affect actions already taken based on the Authorization.
5. To ensure the consent form meets the requirements of a HIPAA Authorization as well as the state law requirements for written consent to release Highly Confidential Information (see [Section 3.3](#)),
 - a. City workforce members must use a City or departmental Authorization form that has been approved by Law when seeking consent to disclose PHI.
 - b. If the request for a disclosure of PHI originates outside the City, any form that contains the required elements (see [Table 5.3](#)) may be accepted although a City form is strongly preferred.
 - c. When Covered Units create new forms or modify existing forms, the City HIPAA Privacy Officer ("CHPO") will review the form to ensure HIPAA and other requirements are met.

PERMITTED USES AND DISCLOSURES

6. If the Authorization is intended to permit the sale of PHI or a use or disclosure for marketing purposes and the City will receive direct or indirect financial payment from another party to disclose the PHI, the Authorization must include a statement to that effect (consult the CHPO).

C. Procedures

1. Departmental management is responsible for designating and routinely training its workforce members whose duties involve releasing PHI in response to an Authorization.
2. When releasing PHI in response to an Authorization, the following steps are required:
 - a. Check the identity of the recipient following the process described in [Section 4.2](#).
 - b. Verify that the Authorization form is valid:
 - i. the expiration date or event has not passed;
 - ii. the form contains the required elements listed in [Table 5.3](#) and was filled out completely; and
 - iii. the Authorization has not been revoked.
 - c. Disclose only the information that is described in the Authorization form.
 - d. If the request includes Highly Confidential Information (see [Section 3.3](#)),
 - i. Confirm the individual has specifically approved disclosure of the Highly Confidential Information (by completing the appropriate sections on the Authorization form);
 - ii. Provide the re-disclosure statement required in [Section 3.3\(C\)\(3\)](#); and
 - iii. Remove or redact any Highly Confidential Information that is not specifically approved on the Authorization form (consult your unit's Privacy Officer or the Law Department).
 - e. Maintain documentation according to your unit's requirements. In most cases, this would include placing in the individual's record:
 - i. a copy of the signed Authorization,
 - ii. a copy of the requestor's ID (or other evidence verifying identity), and
 - iii. confirmation of fulfillment (e.g., date sent, who fulfilled the request, what was released).
3. Authorizations for the use or disclosure of psychotherapy notes cannot be combined with any other Authorizations (a separate form is needed for psychotherapy notes and other PHI).
4. When obtaining an Authorization, workforce members should use an approved City or unit-specific form, explain it to the individual, and provide a signed copy to the individual.
5. If a personal representative signs the Authorization, proof of that person's authority to act on behalf of the individual is required and a copy must be placed in the individual's record.
6. If an individual is competent but physically unable to sign the Authorization, two witnesses must sign the form confirming that the individual understood the nature of the release and freely gave consent.
7. If the individual is a minor (under 18), a parent or legal guardian must sign the Authorization, except the following individuals who can authorize release of their own PHI:
 - a. An emancipated minor: a minor age 16 or older who has left the parental household, supports him/herself financially, and lives independently.
 - b. A minor who has: married, been pregnant, or graduated from high school.
 - c. Any minor may authorize release of PHI related to his or her treatment for pregnancy, sexually transmitted diseases, reproductive health/contraceptives, or substance abuse.
 - d. A minor who is 14 years of age and older may authorize release of his or her mental health treatment records, provided he or she understands the nature of the information and the reason for its use or disclosure.
8. An individual who wishes to revoke an Authorization will be instructed to provide a signed and dated request in writing (unless physically unable, in which case a verbal revocation will be documented), identifying the previously-authorized use or disclosure of PHI that is being revoked. Workforce members will save a copy of

PERMITTED USES AND DISCLOSURES

such written request in the individual's record, with documentation that clearly alerts others to the revocation (for example, adding a note to the revoked Authorization stating "no longer valid").

D. References: 45 CFR § 164.508; 42 CFR § 2.31(a)

TABLE 5.3: CHECKLIST OF REQUIRED ELEMENTS IN A HIPAA AUTHORIZATION

REQUIRED ELEMENTS IN A HIPAA AUTHORIZATION:

- ☐ What health information will be disclosed
- ☐ Who will disclose the information (must name the Covered or Support Unit releasing the record)
- ☐ Who will receive the information
- ☐ The purpose(s) for disclosing the information
- ☐ A statement informing the individual of:
 - (1) his or her right to revoke the Authorization in writing,
 - (2) how to revoke the Authorization, and
 - (3) any exceptions to the right to revoke
- ☐ A statement that the covered entity cannot require the individual to sign the Authorization in order to receive treatment or payment or to enroll or be eligible for benefits
- ☐ A statement that the information may potentially be redisclosed by the recipient and no longer protected by the federal privacy regulations
- ☐ A statement that the Authorization will expire:
 - (1) on a specific date
 - (2) after a specific amount of time (e.g., 5 years), or
 - (3) upon the occurrence of some event related to the patient (e.g., "upon termination of enrollment in the health plan")
- ☐ The signature of the individual and the date.
 - (1) If signed by a personal representative, description of the person's authority to act in that capacity.
 - (2) If the individual is physically unable to sign, signature of two witnesses confirming the individual understood the nature of the release and freely gave consent.
 - (3) If the individual is a minor who does not meet the exceptions listed in [Section 5.3\(c\)\(7\)](#), signature of parent or legal guardian.
- ☐ **Additional elements are required if Highly Confidential Information will be disclosed – consult Law.**

PERMITTED USES AND DISCLOSURES

5.4 FAMILY AND OTHERS INVOLVED IN THE INDIVIDUAL'S CARE

A. Purpose

1. In recognition of the integral role that family and friends play in a patient's health care, HIPAA allows limited protected health information ("PHI") to be disclosed to someone who is not the individual's legally authorized personal representative but is directly involved in an individual's care or payment for care. For example, a health care provider may need to inform a family member of signs or symptoms to watch for, or provide instructions for someone who is assisting the individual after receiving surgery or treatment.
2. In these situations, a written Authorization is not required but informal permission should be obtained by asking the individual outright, or inferred in circumstances that clearly give the individual the opportunity to agree or object. In an emergency situation, where the individual is incapacitated or not available, covered entities must exercise their professional judgment to act in the best interests of the individual.
3. In all cases, disclosures to family members, friends, or other persons involved in the patient's care or payment for care are to be limited to only the PHI directly relevant to the person's involvement in the patient's care or payment for care.

B. Policy

1. Covered Units may make the following disclosures of PHI (except for Highly Confidential Information) without obtaining the individual's written Authorization:
 - a. To a family member, other relative, close personal friend of the individual, or any other person identified by the individual who is **assisting the individual with health care or payment for care**. The other person must clearly be involved in the individual's care or payment and the PHI disclosed must be directly relevant to that person's involvement.
 - b. To a family member, a personal representative of the individual, or another person responsible for the care of the individual, as needed to provide this person **notification of the individual's location, general condition, or death**. This includes disclosures needed to locate or identify a family member or other responsible person.
 - c. To a public or private entity authorized by law or charter to assist in **disaster relief efforts**, for notification purposes in emergency circumstances.
 - d. To a family member, or other persons who were involved in **a deceased individual's care or payment for health care** prior to the individual's death, the PHI that is relevant to such person's involvement, unless doing so is inconsistent with any prior expressed preference of the individual.
2. Workforce members will give the individual (or his or her personal representative) an opportunity to agree or object to disclosures made under this policy whenever possible, as follows:
 - a. If the individual is *present or otherwise available*, and capable of making health care decisions, the disclosures of PHI permitted by this policy may only be made in accordance with the individual's wishes. Generally, the workforce member should ask the individual if he or she agrees to the disclosure, and should give the individual the opportunity to object. However, the workforce member may also disclose PHI in accordance with this policy when, based on his or her professional judgment, it can be reasonably inferred from the circumstances that the individual does not object to the disclosure.
 - b. If the individual is *not present, unavailable, or unable to make health care decisions*, a workforce member may disclose PHI in accordance with this policy when it is in the individual's best interest to do so. This decision may be made by the workforce member, based on his or her professional judgment and common practices in similar situations.

C. Procedures

1. Before disclosing PHI to another person involved in an individual's care (or payment for care), a workforce member should take the following steps:

PERMITTED USES AND DISCLOSURES

- a. As a general rule, ask the individual's permission to share PHI with the other person.
 - b. As an exception to the general rule, the workforce member may disclose PHI to another person when circumstances demonstrate that the individual does not object (such as when a family member accompanies an individual into an exam room).
 - c. If the individual agrees or circumstances demonstrate that the individual does not object, provide PHI only to the person specified by the individual, limited to the minimum necessary PHI that is directly relevant to that person's involvement with the individual's health care or payment.
 - d. Be careful not to disclose any Highly Confidential Information (see below).
 - e. If the individual objects, do not disclose the PHI.
2. Certain types of information may not be disclosed without the individual's written consent. For example, substance abuse treatment information may not be shared without the individual's written consent unless there is a medical emergency. See [Section 3.3](#) and consult with Law for further guidance when Highly Confidential Information is involved.
3. If the individual is not available to agree or object, or is not able to participate in his or her health care due to incapacity, the workforce member may exercise professional judgment to act in the best interests of the individual. Remember, if the individual has a personal representative, such person should be consulted if he or she is available.
4. For minors or adults who lack capacity to make health care decisions, [Section 8.1](#) describes who may receive PHI as a personal representative of that individual.

D. References: 45 CFR § 164.510(b)

PERMITTED USES AND DISCLOSURES

5.5 TREATMENT, PAYMENT, AND HEALTH CARE OPERATIONS

A. Purpose

1. To promote ready access to treatment, efficient payment for health care, and effective operation of the health care system, HIPAA permits covered entities to share protected health information (PHI) for certain treatment, payment, or health care operations activities without the individual's written Authorization.
 - a. **Treatment** generally means the provision, coordination, or management of health care and related services among health care providers or by a health care provider with a third party, consultation between health care providers regarding a patient, or the referral of a patient from one health care provider to another.
 - b. **Payment** encompasses the various activities of health care providers to obtain payment or be reimbursed for their services and of a health plan to obtain premiums, to fulfill their coverage responsibilities and provide benefits under the plan, and to obtain or provide reimbursement for the provision of health care. See [Section 2.1](#) for examples.
 - c. **Health care operations** are any of the following activities:
 - i. Conducting quality assessment and improvement activities, population-based activities relating to improving health or reducing health care costs, and case management and care coordination;
 - ii. Reviewing the competence or qualifications of health care professionals, evaluating provider and health plan performance, training health care and non-health care professionals, accreditation, certification, licensing, or credentialing activities;
 - iii. Underwriting and other activities relating to the creation, renewal, or replacement of a contract of health insurance or health benefits, and ceding, securing, or placing a contract for reinsurance of risk relating to health care claims;
 - iv. Conducting or arranging for medical review, legal, and auditing services, including fraud and abuse detection and compliance programs;
 - v. Business planning and development, such as conducting cost-management and planning analyses related to managing and operating the entity; and
 - vi. Business management and general administrative activities, including those related to implementing and complying with the HIPAA Rules, customer service, resolution of internal grievances, sale or transfer of assets, creating de-identified health information or a limited data set, and fundraising for the benefit of the covered entity.
2. Although HIPAA does not require written Authorization for these types of disclosures, state laws may require a patient's written consent. (See [Section 3.3](#)).

B. Policy

1. Covered Units may share PHI without an Authorization for **treatment** activities, as follows:
 - a. A Covered Unit may disclose PHI to any health care provider for that provider's treatment of the individual. For example, a clinic may send a patient's health care instructions to a nursing home to which the patient is transferred.
 - b. Covered Units that are health care providers (AHS, EMS, PNH, and STDCP) may disclose PHI to another agency or provider, if needed for the Covered Unit's treatment of the individual. The recipient does not need to be a health care provider but the disclosure must be for a service that is *a necessary component of or may help further the individual's health care*. For example, a health care provider may disclose PHI (except Highly Confidential Information) about a patient needing health care supportive housing to a service agency that arranges such services for individuals.
 - c. As a clinical laboratory, PHL is very limited by its licensing laws and can only disclose lab results and reports to the physician who ordered the test and the individual who was tested (see [Section 3.3](#)).
2. Covered Units may share PHI without an Authorization for **payment** activities, as follows:

PERMITTED USES AND DISCLOSURES

- a. A Covered Unit may disclose PHI to the extent needed for its own payment activities.
 - b. A Covered Unit may disclose PHI to another covered entity or a health care provider for the payment activities of the receiving entity or provider. For example, a physician may send an individual's health plan coverage information to a laboratory who needs the information to bill for services it provided to the physician with respect to the individual.
 - c. Some types of Highly Confidential Information may be restricted (refer to [Table 3.3](#)).
3. Covered Units may share PHI that is not Highly Confidential Information without an Authorization for **health care operations** activities, as follows:
 - a. A Covered Unit may disclose PHI for its own health care operations activities, to a Support Unit or business associate (under an appropriate MOU or BAA, see [Sections 3.1](#) and [5.6](#)).
 - b. A Covered Unit may disclose PHI to another Covered Unit or covered entity, if each entity (i) has or had a relationship with the individual who is the subject of the information; (ii) the PHI pertains to the relationship; and (iii) the disclosure is for a quality-related activity (the activities listed in paragraphs (a) and (b) of the definition of "health care operations") or for the purpose of health care fraud and abuse detection or compliance.
 - c. Most types of Highly Confidential Information are restricted (refer to [Table 3.3](#)).
4. Support Units may only disclose PHI to the extent permitted in the underlying Memorandum of Understanding ("MOU") with the Covered Unit for which the Support Unit is providing services.

C. Procedures

1. When disclosing PHI for treatment or payment activities within the normal business activities of the Covered Unit, workforce members will follow the general procedures in [Section 5.2](#). In situations outside of the normal business activities, or if there is any doubt about whether the disclosure is permissible, the Privacy Officer should be consulted.
2. Before disclosing PHI for health care operations activities, workforce members will confirm with their supervisor or their unit's Privacy Officer that an appropriate BAA or MOU exists specifically authorizing such disclosures (see [Section 3.1](#) if disclosing to another part of the City or [Section 5.6](#) if disclosing to someone outside the City).
3. Disclosures for treatment, payment, and health care operations are not required to be tracked (see [Section 3.3](#)).

D. References: 45 CFR § 164.506

PERMITTED USES AND DISCLOSURES

5.6 BUSINESS ASSOCIATES

A. Purpose

1. The City often contracts with other organizations or individuals who are not members of the City's workforce to perform services that involve access to the City's protected health information ("PHI"). This may include project-based services such as computer system maintenance, accounting, legal services, quality improvement studies, or long-term functions that the City has outsourced (for example, billing services for EMS or benefit management services for the employee health plan).
2. HIPAA allows covered entities such as the City to share PHI with these types of contractors, called "business associates," without Authorization from the individuals whose PHI is being shared. Instead, a written agreement must be in place providing satisfactory assurance that the business associate will appropriately safeguard the PHI (a "**business associate agreement**" or "BAA").
3. This policy establishes standards for identifying business associates and establishing formal business associate agreements between the City and its business associates to ensure that PHI will be safeguarded and that the City will have adequate access to PHI maintained by business associates.

When Covered Units engage other City departments, divisions, units, or their workforce members to provide "business associate" type services on behalf of the Covered Unit, the other City unit or person becomes a **Support Unit**. Support Units are essentially functioning as "business associates" of the Covered Units but are not business associates because they are part of the City workforce. [Section 3.1](#) explains the relationship between a Covered and Support Unit and their respective obligations, including executing a Memorandum of Understanding ("MOU") that is similar to a BAA.

B. Policy

1. A **business associate** is any person or entity (outside of the City workforce) that:
 - a. creates, receives, maintains, or transmits PHI on behalf of a Covered Unit to perform a function or activity regulated by HIPAA, including claims processing or administration, data analysis, processing or administration, utilization review, quality assurance, patient safety activities, billing, benefit management, practice management, or repricing;
 - b. provides services to or for the Covered Unit involving access to PHI, including legal, actuarial, accounting, consulting, data aggregation, management, administrative, accreditation, or financial services; or
 - c. is responsible for creating, receiving, maintaining, or transmitting a Covered Unit's PHI on behalf of a Support Unit or another business associate (i.e., a subcontractor that is assisting a Support Unit or other business associate with the activities described above).
2. A Covered Unit may disclose PHI to a business associate when authorized to do so by a fully executed written agreement between the parties that contains the mandatory BAA language approved by the Law Department.
3. A Support Unit may disclose PHI to a business associate who is assisting the Support Unit in providing services to a Covered Unit (a "subcontractor") only when:
 - a. Authorized to do so by the underlying MOU between the Support and Covered Unit; and
 - b. A written agreement has been executed between the subcontractor and the Support Unit (or the Covered Unit, in some cases) containing the mandatory BAA language approved by Law.
4. Each Covered or Support Unit is responsible for identifying which of its contractors or subcontractors are business associates (see [Table 5.6](#)), executing an appropriate BAA with each of its business associates, overseeing the management of its business associate relationships, and maintaining documentation of its BAAs.
5. If a Covered or Support Unit becomes aware that one of its business associates is violating its BAA with the City, the Covered or Support Unit will work with the Law Department to require the business associate to cure the violation or end the agreement.

PERMITTED USES AND DISCLOSURES

C. Procedures

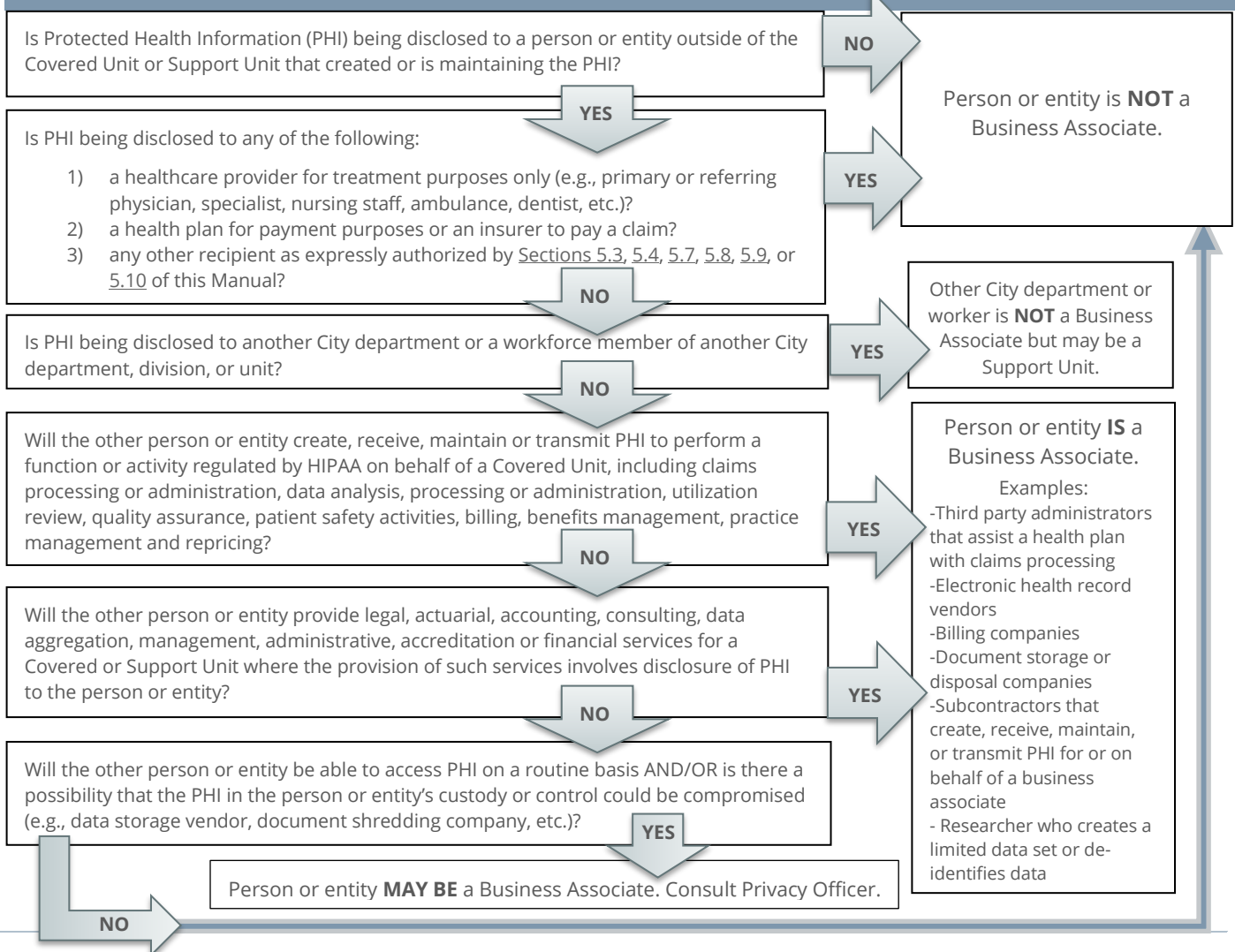
1. *Engaging a Business Associate.* Before engaging a contractor to perform any services or functions involving access to City PHI, workforce members within the Covered or Support Unit responsible for initiating the contract and/or managing the relationship with the contractor will work with their contract/conformance manager and the Law Department to determine whether the contractor is a business associate, and, if so, ensure that an agreement containing appropriate BAA language is executed.
 - a. The Law Department has approved standard BAA terms that must be included without revision in all contracts that are not individually reviewed by the CHPO (the "City PHI Terms") (available at <http://mbec.phila.gov/procurement/forms/Terms%20Relating%20To%20PHI.pdf>).
 - b. Depending on the services performed by the business associate, additional terms may be necessary. In situations where the business associate will have extensive access to PHI or perform any of the below-listed services, the Covered or Support Unit initiating the relationship will consult with their Law Department representative, who will collaborate with the CHPO to provide additional BAA terms. Activities requiring additional BAA terms include, for example:
 - i. Creating PHI on the City's behalf or warehousing City PHI,
 - ii. Maintaining a Designated Record Set (see [Section 3.2](#)),
 - iii. De-identifying PHI or creating a Limited Data Set (see [Section 3.4](#)), or
 - iv. Providing data aggregation services. "Data aggregation" means the combining of City PHI with the PHI of other organizations, to permit data analyses of the combined data.
 - c. Note: Contractors who do not have access to PHI in connection with performing their duties under their contracts are not business associates, but may be required to sign a confidentiality agreement to protect information that is not PHI but is still confidential.
2. *Security Review of Business Associate.* At the request of the unit's Security Officer or City HIPAA Security Officer, the City may conduct a security review of a business associate to assess its compliance with HIPAA security requirements. The Office of Innovation and Technology ("OIT") will provide direction regarding what information is needed to conduct a security review, which may include the following:
 - a. A risk assessment completed by (or for) the business associate covering all of the applicable physical, technical and administrative safeguards, as well as policies and procedures.
 - b. If necessary, a corrective action plan indicating how the business associate will correct any deficiencies reflected in its risk assessment.
 - c. Registration of all information systems with OIT to ensure that all software and hardware handling ePHI are scanned for potential vulnerabilities.
3. *Managing the Business Associate Relationship.* The Covered or Support Unit will designate a person who is responsible for each business associate relationship. When such person becomes aware of a violation of the business associate's contract with the City relating to HIPAA or the BAA terms, he or she will promptly notify the unit's Privacy Officer/Liaison and the Law Department representative. The Law Department representative will coordinate with the CHPO and the unit to take appropriate action to have the violation cured or the agreement terminated.
4. Documentation
 - a. The Covered or Support Unit signing the BAA will send a copy of the executed contract to their contract representative in the Law Department.
 - b. Business associate contracts must be maintained for a period of at least six years after the date the contract is no longer in effect.
 - i. Contracts originating in the ACIS system will be retained by the Law Department.
 - ii. Contracts maintained in the Procurement e-contracting system will be retained by Procurement.
 - iii. Any other contracts with business associates that are not maintained in ACIS must be maintained by the originating unit as part of its HIPAA Documentation.

PERMITTED USES AND DISCLOSURES

- c. Covered and Support Units will also maintain copies of all executed BAAs for a period of at least three years after the contract is no longer in effect, for purposes of monitoring the business associate's compliance with the BAA.
- d. The Privacy Officer/Liaison of each Covered or Support Unit, in cooperation with the unit's conformance manager, is responsible for maintaining a list of all the unit's business associates, including the following information:
 - i. Name of business associate
 - ii. Business associate contact information (including the name, title, address, phone, fax, and email of a contact person)
 - iii. Type of services or functions the BA is providing
 - iv. Effective date and term of underlying contract
 - v. Date BAA was fully executed (if separate from underlying contract)
 - vi. Name of workforce member responsible for the relationship
 - vii. Any additional notes, such as the next scheduled review date

D. References: 45 CFR §160.103, 164.308(b), 164.314, 164.502(e), 164.504(e)

FIGURE 5.6: BUSINESS ASSOCIATE REFERENCE GUIDE



PERMITTED USES AND DISCLOSURES

5.7 PUBLIC HEALTH AND SAFETY REPORTING

A. Purpose

1. HIPAA permits limited disclosures of protected health information ("PHI") to be made without an individual's Authorization, when necessary for public health activities, abuse reporting, and other activities that are high priorities for the safety or well-being of the public.
2. Generally, HIPAA permits covered entities to disclose PHI for public health and safety purposes when and to the extent required to do so by other state or federal laws. In Pennsylvania, state laws require reporting of births, deaths, some communicable diseases, and specific types of wounds and injuries. Health care providers and other professionals who work with children are also required to report suspected cases of child abuse or neglect.
3. In limited circumstances, HIPAA permits disclosures to be made that are not specifically required by law but are necessary to carry out certain public health and safety activities. For example, a health care provider may need to notify a patient that he or she has been exposed to an infectious disease. While not mandatory, cases of suspected abuse, neglect or domestic violence directed at adults may also be reported under certain circumstances.
4. This policy provides standards for City workforce members to disclose PHI (a) for public health activities, (b) to report abuse, neglect, or domestic violence, (c) for other reporting required by law, and (d) as needed by coroners, medical examiners, or funeral directors.

B. Policy

1. A Covered or Support Unit may authorize its workforce members to disclose PHI without the individual's Authorization, for the following **public health activities**:
 - a. Reporting to a public health authority that is authorized by law to collect or receive such information for the purpose of preventing or controlling disease, injury, or disability, or to an official of a foreign government agency that is acting in collaboration with a public health authority. This includes:
 - i. routine reporting of births, deaths, communicable diseases, and certain injuries; and
 - ii. disclosures requested by a public health authority to conduct public health surveillance, investigations or interventions.
 - b. Reporting to someone under the jurisdiction of the federal Food and Drug Administration (for example, a drug manufacturer), regarding the quality, safety or effectiveness of regulated products and activities. This includes reports of adverse events, product tracking information, and post marketing surveillance information.
 - c. Notifying individuals that they may have been exposed to a communicable disease, or may otherwise may be at risk of contracting or spreading a disease or condition. This only applies when the Covered Unit is authorized by law to notify such person in the conduct of a public health intervention or investigation.
 - d. Providing proof of immunization to a school, as permitted by 45 CFR § 164.512(b)(1)(vi).
 - e. Certain occupational health reporting to an employer, as permitted by 45 CFR § 164.512(b)(1)(v).
2. A Covered or Support Unit may authorize its workforce members to disclose PHI to a public health or other government authority authorized by law to receive **reports of abuse, neglect or domestic violence**, as follows:
 - a. Workforce members who are mandated reporters under Pennsylvania's Child Protective Services Law (CPSL) or Older Adults Protective Services Act (OAPSA) may disclose PHI to the extent required to meet their legal obligations, without the individual's Authorization. For example:
 - i. Health care professionals, social workers, and other professionals who work with children are required by the CPSL to report suspected child abuse. (23 Pa.C.S. § 6311)

PERMITTED USES AND DISCLOSURES

- ii. Certified medical practitioners are required by the CPSL to disclose certain medical information when an assessment for general protective services or a child abuse investigation is being conducted or when the family has been accepted for services by a protective services agency. (23 Pa.C.S. § 6340.1)
 - iii. Staff of nursing homes and similar facilities are required by the OAPSA to report suspected abuse of older adults. (35 P.S. § 10225.701)
 - b. Workforce members may disclose PHI to report abuse, neglect, or domestic violence *beyond what is required by law* in the following situations:
 - i. If the individual agrees to the disclosure (permission may be given verbally or in writing and needs to be documented in the individual's record);
 - ii. There is a law or regulation authorizing the disclosure and a health care professional in his or her professional judgment believes the disclosure is necessary to prevent additional harm to the individual or other potential victims; or
 - iii. In an emergency situation when the individual is unable to agree to the disclosure and the information is necessary for an immediate law enforcement activity. In this case, there must be a law or regulation authorizing the disclosure; and the law enforcement or other public official authorized to receive the report must represent that the PHI will not be used against the individual and the enforcement activity would be materially and adversely affected by waiting until the individual is able to agree to the disclosure.
 - c. When reporting suspected abuse, neglect, or domestic violence (other than child abuse), the individual whose PHI was disclosed must be notified as described in paragraph C(3) below.
3. A Covered or Support Unit may authorize its workforce members to disclose PHI to a law enforcement official or other recipient, **when and to the extent required by law** (for example, mandatory reporting of certain types of wounds or other physical injuries).
4. A Covered Unit may authorize its workforce members to disclose PHI **to a coroner or medical examiner** for the purpose of identifying a deceased person, determining a cause of death, or other duties as authorized by law; or to a funeral director as needed to arrange the decedent's funeral.

C. Procedures

1. Routine reporting under a unit-specific protocol.
 - a. Each Covered or Support Unit whose workforce members are permitted to make routine public health or abuse reports will develop and maintain a protocol identifying:
 - i. Diseases, conditions, injuries and types of abuse that are required to be reported by federal, state, or local law (for example, PA Dept. of Health list of reportable diseases);
 - ii. What information must be provided for each type of report;
 - iii. To whom the information will be disclosed; and
 - iv. Who is authorized to make such reports (for example, listing the mandated reporters who are required to report child abuse).
 - b. If workforce members are authorized to report abuse, neglect, or domestic violence beyond what is required by law, the protocol will specify who is authorized to make these reports, and other procedural requirements to comply with paragraph B(2)(b) above.
 - c. Any other types of routine reporting permitted under paragraphs B(3) or B(4) will be addressed in the protocol.
 - d. The unit's Privacy Officer/Liaison is responsible for periodically updating the protocol and obtaining review by the Law Department and City HIPAA Privacy Officer ("CHPO") to ensure it complies with HIPAA and other legal requirements.
2. Any disclosure that is not listed in the protocol, or requests for PHI beyond what is specified in the protocol, must be reviewed and approved by the unit's Privacy Officer/Liaison, in consultation with the CHPO as necessary.

PERMITTED USES AND DISCLOSURES

3. When reporting suspected abuse, neglect, or domestic violence other than child abuse, the workforce member must notify the individual that the report was or will be made, except as follows:
 - a. A personal representative should NOT be notified if there is reason to believe that the personal representative is responsible for the abuse, or that informing this person of the report of suspected abuse would jeopardize the patient.
 - b. An individual should NOT be notified if doing so would place the individual at risk of serious harm.
4. All disclosures described in this Section must be tracked as required by [Section 4.3](#).

D. References: 45 CFR § 164.512 (a), (b), (c), (f)(1)(i), and (g); 23 Pa.C.S. § 6311, 35 P.S. § 10225.101 et seq.

PERMITTED USES AND DISCLOSURES

5.8 COURT ORDERS, SUBPOENAS, AND WARRANTS

A. Purpose

1. HIPAA allows covered entities to disclose protected health information ("PHI") without an individual's written Authorization, when and to the extent required by a court order, court-ordered warrant, or grand jury subpoena.
2. When certain conditions are met, PHI may also be disclosed in response to a subpoena or discovery request issued in the course of a judicial or administrative proceeding or a law enforcement investigation and is signed by someone other than a judge, magistrate, or, administrative tribunal. These requests typically either seek testimony by a witness or production of documents, both of which may involve the disclosure of PHI.
3. The requirements for disclosing PHI pursuant to these types of requests differ depending on what type of request has been issued. The requests can be grouped into 3 categories, as follows:
 - a. **Category A: court orders signed by a judge, magistrate, or administrative tribunal.** This category includes court-ordered warrants, subpoenas or summons signed by a judge, and grand jury subpoenas.
 - b. **Category B: subpoenas or other discovery requests issued in the course of a judicial or administrative proceeding.** This category includes subpoenas, discovery requests, and other legal requests signed by a person other than a judge, magistrate, or administrative tribunal.
 - c. **Category C: law enforcement demands.** This category includes administrative subpoenas, summons, investigative demands, or similar process authorized by law in a law enforcement activity.

B. Policy

1. **Category A.** In response to a valid court order, court-ordered warrant, subpoena or summons signed by a judge, or grand jury subpoena, the Covered or Support Unit may disclose only the PHI that is expressly ordered to be disclosed.
2. **Category B.** In response to a subpoena or other lawful process signed by a person other than a judge, magistrate, or administrative tribunal (e.g., it is signed by a lawyer, prosecutor, court clerk, etc.), PHI will not be disclosed unless and until the Covered or Support Unit has satisfied **ONE** of the following:
 - a. Contact the individual whose PHI is being requested in writing, explain that the City has received a subpoena requiring disclosure of the individual's PHI, and notify the individual that the City is required to respond unless the individual quashes the subpoena and notifies the City before the deadline for responding to the subpoena. If the Covered or Support Unit does not know the current address of the individual, a letter and a copy of the subpoena should be sent to the individual's last known address and document the same. Once the Covered or Support Unit sends such notice, the burden is on the individual to quash the subpoena if he or she wants to protect the information.
 - b. Obtain satisfactory written assurances from the entity issuing the subpoena that either:
 - i. the entity made a good faith attempt to give the individual written notice of the subpoena, the notice included sufficient information to permit the individual to object to the subpoena, and the time for raising objections has passed or the court ruled against the individual's objections; or
 - ii. the parties have agreed on a protective order or the entity seeking the information has filed for a qualified protective order.
 - c. Obtain a valid HIPAA Authorization from the individual (see [Section 5.3](#)).
3. **Category C.** In response to an administrative subpoena, summons, investigative demand, or similar process authorized by law in a law enforcement activity, the Covered or Support Unit may comply with the request if the issuing entity confirms:
 - a. the information sought is relevant and material to a legitimate law enforcement inquiry;
 - b. the request is specific and limited to the extent reasonably necessary for the purpose of the request; and
 - c. de-identified information could not reasonably be used.

PERMITTED USES AND DISCLOSURES

4. In all cases where disclosure is required, the PHI disclosed will be limited to the strict terms of the subpoena, order or warrant, including the scope of the information disclosed and the timing of disclosure. If the subpoena, order or warrant only requires disclosure of written items, no PHI will be disclosed orally. If a subpoena requires disclosure at a specific time, the PHI will not be disclosed before the deadline without the individual's consent because doing so may deprive the individual of the opportunity to quash the subpoena.
5. Before a disclosure of PHI is made under this Section, the following approvals are required:
 - a. Disclosures of PHI requested from Covered Units will be approved by the unit's Privacy Officer or the City HIPAA Privacy Officer ("CHPO").
 - b. Disclosures of PHI requested from Support Units will be approved by the CHPO or the Privacy Officer of the Covered Unit whose PHI was requested.
 - c. Any disclosure of Highly Confidential Information will be approved by the CHPO or the Law Department's Health and Adult Services Unit.

C. Procedures

1. Per City policy, any person attempting to serve Covered or Support Unit with a court order, warrant, subpoena, or summons will be directed to the Law Department, 1515 Arch Street, 14th Floor. Law will review the document to ensure it is properly served, complies with applicable court rules, and was issued by a court or authority with appropriate jurisdiction over the City.
2. If the Law Department accepts a court order, warrant, subpoena, or summons and approves it as to form, it will be sent to the designated contact within the department or unit maintaining the requested records (for example, the Privacy Officer, Administrative Services Director, Administrative Services Coordinator, or Clinical Supervisor).
3. For requests for information maintained by a Covered Unit:
 - a. The Covered Unit will obtain approval from the unit's Privacy Officer before responding to any court order, warrant, subpoena, or summons seeking the disclosure of PHI (either by oral testimony or through releasing written records).
 - b. The Privacy Officer will review the request and take the following steps:
 - i. Determine whether it is a Category A, B, or C request (as described above).
 - ii. Determine whether the conditions relevant to that category have been met. For example, for a subpoena in Category B, confirm that a notice of intent was provided to the individual whose PHI was requested, and the required time period (20 days) has passed without objection. Seek advice from the CHPO as needed.
 - iii. Review the information to be disclosed to determine if it includes any Highly Confidential Information (see [Section 3.3](#)). If Highly Confidential Information is requested, seek advice from the CHPO or the Law Department's Health and Adult Services Unit.
 - iv. If all conditions have been met, approve the release of the PHI. Any release of Highly Confidential Information requires written approval by the CHPO or Law Department or the individual's written Authorization.
 - v. Ensure a copy of the request and documentation of the response is saved in the individual's record.
 - vi. Maintain a copy of the request as part of the unit's HIPAA Documentation.
 - c. Upon approval by the Law Department and CHPO, a Covered Unit may establish a protocol requiring all court orders, warrants, subpoenas, or summons to be reviewed and approved by the Law Department rather than the Privacy Officer. In such case, steps (i) – (iv) of the above paragraph may be performed by Law rather than the Privacy Officer.
4. For requests for information maintained by a Support Unit: The Support Unit will obtain approval from the CHPO or the Privacy Officer of the Covered Unit whose PHI was requested before responding to any court order, warrant, subpoena, or summons seeking the disclosure of PHI maintained by the Support Unit on behalf of a Covered Unit.

PERMITTED USES AND DISCLOSURES

5. No original records may be released to any person or entity without receiving written approval from the Law Department.
6. Any fees charged for producing records will comply with the Pennsylvania Department of Health regulations establishing maximum search, retrieval, and reproduction fees.
7. All disclosures described in this Section must be tracked as required by [Section 4.3](#).

D. References: 45 CFR § 164.512 (e) and (f)(1)(ii)

PERMITTED USES AND DISCLOSURES

5.9 RESEARCH

A. Purpose

1. HIPAA allows covered entities to use and disclose PHI for research if authorized to do so by the research subjects, and, in certain circumstances described in this policy, without such Authorization.
2. An Institutional Review Board (IRB) is a board, committee, or other group formally designated by an institution to review research involving humans as subjects. IRBs have authority to approve, require modification to, or disapprove all research activities covered by the Common Rule (45 CFR Part 46, Subpart A) and/or the human subject protection regulations (21 CFR Parts 50 and 56). A Privacy Board (PB) is an alternative review board authorized by HIPAA to review requests for alteration or waiver of a research Authorization.
3. An IRB/PB may approve a waiver or an alteration of the HIPAA Authorization requirement in whole or in part for research uses and disclosures of PHI. A waiver or alteration of the HIPAA Authorization (as set forth at 45 CFR § 164.512(i)(1)(i)) is distinct from a waiver or alteration of the informed consent requirements (as set forth at 45 CFR §§ 46.116 and 46.117).
4. A complete HIPAA waiver occurs when the IRB/PB determines that the covered entity may use and disclose PHI for a research project without obtaining an Authorization from each individual research subject. A partial waiver occurs when an IRB/PB determines that a covered entity does not need Authorization for certain uses and disclosures, such as disclosing PHI for research recruitment purposes. An alteration occurs when a IRB/PB approves a request to modify the requirements of an Authorization (in which case the researcher must collect modified Authorizations from all subjects).

B. Policy

1. Clinical research involving City PHI requires the written approval of the head of any participating Covered Unit (or his/her designee).
2. City PHI may be used and disclosed for research purposes in several ways:
 - a. As permitted in a HIPAA-compliant **Authorization** (see [Section 5.3](#));
 - b. In the form of a **Limited Data Set** under a data use agreement (see [Section 3.2](#));
 - c. As permitted in a modified Authorization approved by the IRB (an “**Alteration**”);
 - d. Under a Waiver of Authorization approved by the IRB (a “**Waiver**”);
 - e. For research solely involving the PHI of deceased individuals; and
 - f. For certain activities preparatory to research.
 - g. Note: After it has been properly de-identified as described in [Section 3.4](#), **De-Identified Information** is no longer PHI and may be used or disclosed for research.
3. The Philadelphia Department of Public Health IRB (operating under 21 CFR § 56.107 and 45 CFR § 46.107) is authorized to approve Alterations or Waivers involving the use or disclosure of City PHI for research. For any Alteration or Waiver approved by a different IRB, the head of the Covered Unit must determine whether the Covered Unit’s PHI may be disclosed in accordance with such non-City IRB/PB approval. An Alteration or Waiver approved by a Privacy Board is not sufficient unless approved by the City HIPAA Privacy Officer.
4. A valid Alteration or Waiver must include all of the following elements:
 - a. The identity of the approving IRB;
 - b. The date on which the waiver or alteration was approved;
 - c. A statement that the IRB has determined that all the specified criteria for a waiver or an alteration were met (as set forth at 45 CFR § 164.512(i)(2)(ii));
 - d. A brief description of the PHI for which use or access has been determined by the IRB to be necessary in connection with the specific research activity;

PERMITTED USES AND DISCLOSURES

- e. A statement that the waiver or alteration was reviewed and approved under either normal or expedited review procedures (see 45 CFR § 164.512(i)(2)(iv)); and
 - f. The required signature of the IRB chair or the chair's designee.
- 5. A Covered Unit may disclose PHI of deceased individuals for research without obtaining individual Authorizations, if the researcher provides to the Covered Unit's Privacy Officer:
 - a. oral or written representations that the use or disclosure is sought solely for research on the PHI of decedents and the PHI requested is necessary for the research purposes; and
 - b. documentation of the death of such individuals.
- 6. Covered Units may allow a researcher to view PHI on-site as necessary to prepare a research protocol or for similar purposes preparatory to research, when the unit's Privacy Officer has approved the activity; for example, to identify prospective research participants. No PHI may be taken off premises (including copies, screenshots, or notes containing PHI).
- 7. Support Units may only disclose PHI to the extent permitted in the underlying Memorandum of Understanding with the Covered Unit for which the Support Unit is providing services.
- 8. Per City policy, any disclosure of City PHI or De-Identified Information for research requires a data license agreement to be executed between the City and any outside researcher or other recipient.

C. Procedures

- 1. The principal investigator or other person responsible for the conduct of a research project must obtain approval from the head of the Covered Unit. Approval of the research proposal must be documented before the IRB will grant a Waiver or Alteration.
- 2. After approval is received from the head of the Covered Unit, the principal investigator, or other person responsible for the conduct of a research project, may request a Waiver or Alteration from the IRB in accordance with procedures established by the IRB. If PHI is requested from Covered Units within PDPH, EMS, or DBHIDS, the request must be submitted to the PDPH IRB.
- 3. The use or disclosure of PHI for the research project may not begin until written approval (in compliance with this policy) is provided by the IRB to the principal investigator or other responsible person for the conduct of the research project.
- 4. If PHI is requested for research relating solely to deceased individuals or for activities preparatory to research (without obtaining Authorizations, a Data Use Agreement, or IRB approval), the Covered Unit's Privacy Officer must approve the use or disclosure of PHI, in writing, before the researcher may have access to the requested PHI.
- 5. Disclosures for research must be tracked as required by [Section 4.3](#).
- 6. Documentation related to Waivers and Alterations will be retained by the IRB for at least six years after the date that the study was completed and in accordance with IRB file retention protocols.

D. References: 45 CFR § 164.512(i), 45 CFR §§ 46.116 and 46.117

PERMITTED USES AND DISCLOSURES

5.10 OTHER REASONS FOR DISCLOSING PHI

A. Purpose

1. There are several situations beyond those described in [Sections 5.4-5.9](#) in which HIPAA permits a disclosure of protected health information (PHI) without an individual's written Authorization. Generally, these situations occur infrequently and require case-by-case review to determine whether, and to what extent, the PHI sought or requested may be disclosed.
2. This policy provides standards for City workforce members to disclose PHI:
 - a. for health oversight activities,
 - b. for certain law enforcement purposes,
 - c. for organ and tissue donation,
 - d. to avert a serious threat to health or safety,
 - e. for specialized government functions,
 - f. as authorized by workers' compensation laws, or
 - g. for marketing or fundraising purposes.

B. Policy

1. Covered Units may disclose PHI without the individual's Authorization, after appropriate review and approval by the unit's Privacy Officer, for the following activities and purposes:
 - a. To a **Health Oversight Agency for Health Oversight Activities**, as authorized by law. This includes activities necessary for appropriate oversight of the health care system, government benefit programs, or entities subject to regulatory programs or civil rights laws for which PHI is necessary for determining compliance with the program. For example, PHI may be requested during a billing audit by the Centers for Medicare & Medicaid Services, an inspection by the Pennsylvania Department of Health, or a chart audit by an agency authorized to oversee federally-funded vaccine programs.
 - b. To a Law Enforcement Official for Law Enforcement Purposes, under the following conditions:
 - i. When the subject of the PHI is an individual who is or is suspected to be a victim of a crime, if the individual agrees to the disclosure (or is unable to agree but the requirements of 45 CFR § 164.512(f)(3)(ii) have been met);
 - ii. Limited PHI for the purpose of identifying or locating a suspect, fugitive, material witness, or missing person (only the PHI listed in 45 CFR § 164.512(f)(2) may be disclosed);
 - iii. Limited PHI about the suspected perpetrator of a crime, when the disclosure is made by a workforce member who is the victim of such crime (only the PHI listed in 45 CFR § 164.512(f)(2)(i) may be disclosed);
 - iv. About an individual who has died, for the purpose of alerting law enforcement of a death suspected to have resulted from criminal conduct;
 - v. If the PHI constitutes evidence of criminal conduct that occurred on the disclosing unit's premises; or
 - vi. By a health care provider responding to a medical emergency, when it appears necessary to alert law enforcement to the commission and nature of a crime; location of such crime or the victim(s) of such crime; or the identity, description, and location of the perpetrator of such crime. If the medical emergency is the result of abuse, neglect, or domestic violence, refer to [Section 5.7\(B\)\(2\)](#) rather than this paragraph.
 - c. **For Cadaveric Organ, Eye or Tissue Donation Purposes**, to organ procurement organizations or other entities engaged in the procurement, banking, or transplantation of organs, eyes or tissues for the purpose of facilitating donation or transplantation.
 - d. **To Avert a Serious Threat to Health or Safety**, upon a belief in good faith that the use or disclosure is necessary to prevent or lessen a serious and imminent threat to the health or safety of a person or the public. The recipient must be a person reasonably able to prevent or lessen the threat, or a law

PERMITTED USES AND DISCLOSURES

enforcement authority who is apprehending an individual who has caused serious harm to a victim or escaped from a correctional facility.

- e. **For Specialized Government Functions**, including disclosures of an inmates' PHI to correctional institutions and disclosures of individual's PHI to authorized federal officials for the conduct of national security activities.
 - f. **For Workers' Compensation Programs**, to the extent necessary to comply with laws relating to workers' compensation or other similar programs.
2. Any use or disclosure of PHI **for a marketing or fundraising purpose** (as those terms are defined in [Section 2.1](#)) requires the individual's Authorization, unless the City HIPAA Privacy Officer ("CHPO") reviews and approves an exception based on what is permissible under HIPAA and other applicable laws.
 3. Support Units may only disclose PHI to the extent permitted in the underlying Memorandum of Understanding ("MOU") with the Covered Unit for which the Support Unit is providing services.

C. Procedures

1. Workforce members will direct any request for PHI for an activity or purpose listed above to their unit's Privacy Officer. The Privacy Officer will review the request and consult with the City HIPAA Privacy Officer ("CHPO"), who will approve only those disclosures that are determined to be consistent with HIPAA and other applicable laws.
2. If a Covered Unit makes routine or recurring disclosures for an activity or purpose listed above, the Covered Unit may authorize such disclosures in protocol(s) approved by the unit's Privacy Officer and the CHPO. Workforce members may disclose PHI in accordance with such pre-approved protocols without seeking case-by-case review and approval.
3. A workforce member who is making a good faith report of illegal behavior, clinical malpractice, or dangerous conditions within his or her unit may disclose the minimum PHI necessary to the appropriate oversight agency authorized by law to investigate such conduct. Prior approval from the Privacy Officer is not required; however, the workforce member is strongly encouraged to consult with departmental leadership and/or the Law Department prior to making an external report, so that the City may investigate and take appropriate corrective action.

D. References: 45 CFR §§ 164.502(j)(2), 164.508(a)(3), 164.512(d), (f), (h), (j), (k), & (l), 164.514(f)

SAFEGUARDING PROTECTED HEALTH INFORMATION

6.0 Safeguarding Protected Health Information

A. Purpose

1. Covered entities are required to use reasonable administrative, physical, and technical safeguards to limit unauthorized and incidental uses or disclosures of protected health information (PHI).
2. An incidental use or disclosure is a secondary use disclosure that cannot reasonably be prevented, is limited in nature, and that occurs as a by-product of an otherwise permitted use or disclosure. For example: a conversation that is overheard despite attempts by the speakers to avoid being heard.
3. HIPAA permits certain incidental uses and disclosures, as long as reasonable safeguards are used and minimum necessary standard is applied.

B. Policy

1. All workforce members will follow these procedures in handling PHI to prevent unauthorized uses and disclosures, to limit incidental uses and disclosures, and to meet the Minimum Necessary Standard (see [Section 4.1](#)).
2. Workforce members are also required to follow all departmental HIPAA privacy and security policies, procedures, or protocols, as well as the Office of Innovation and Technology (OIT) Governance Policies.
3. All workforce members are required to watch for unauthorized uses or disclosures of PHI, to act to prevent the action, and to report suspected breaches of privacy and security policies to their supervisors (for example, an individual or visitor looking through PHI left on a counter). See [Chapter 7, "Reporting Incidents."](#)

C. Procedures

1. Safeguards for the Physical Environment
 - a. Bulletin Boards
 - i. Bulletin boards that are located in areas where they may be seen by individuals or visitors may not contain any PHI, unless all of the individuals whose PHI appears on the bulletin boards have authorized the display (see [Section 5.3](#)).
 - ii. For example, this includes: pictures of individuals (patients, clients or consumers), even without a name or other identifying information; cards and notes of appreciation.
 - b. Computer Screens
 - i. Computer screens at each workstation must be positioned so that only authorized users at that workstation can read the display. When screens cannot be relocated, filters, hoods, or other devices may be employed.
 - ii. Computer displays will be configured to go blank, or to display a screen saver, when left unattended for more than a brief period of time. The unit's Privacy and Security Officers will determine the period of time. Wherever practicable, reverting from the screen saver to the display of data will require a password.
 - iii. Computer screens left unattended for longer periods of time will log off the user. The unit's Privacy and Security Officers will determine the period of time.
 - c. Conversations
 - i. Conversations concerning an individual's care or other PHI must be conducted in a way that reduces the likelihood of being overheard by others, for example, by speaking quietly, avoiding discussions in public spaces, etc.
 - ii. Wherever reasonably possible, barriers will be used to reduce the opportunity for conversations to be overheard.
 - d. Desks, countertops, printers, and fax machines

SAFEGUARDING PROTECTED HEALTH INFORMATION

- i. Measures (such as filing in folders and/or turning over top paper on a pile) will be taken to prevent individuals and visitors from seeing information inappropriately.
 - ii. Printers and fax machines must be located in secure areas, where only authorized members of the workforce can have access to documents being printed.
 - e. Sign-in lists
 - i. Sign-in sheets may be used only when necessary for patient care and efficient operations.
 - ii. Sign-in sheets must not include any information other than the patients' names.
 - iii. Departments or units treating patients with mental health, substance abuse, communicable disease, or other highly confidential conditions, should ensure that subsequent signers cannot identify previous signers.
- 2. Safeguards for Transmitting PHI by Telephone, Fax, and Mail
 - a. Workforce members must take the following precautions when transmitting PHI via fax:
 - i. All faxes containing PHI must be accompanied by a cover sheet that includes a confidentiality notice.
 - ii. Frequently used fax numbers should be preprogrammed into fax machines or computers to avoid misdialing errors. Preprogrammed numbers should be verified on a routine basis.
 - iii. Fax numbers should be double checked before and after sending.
 - iv. In some instances (depending on the sensitivity of the information), the receiver should be called to assure receipt of information.
 - b. When sending PHI in the mail, the address must be double checked and the envelope must be securely sealed. Contents should be reviewed to ensure no additional pages were included and no other individual's PHI was inadvertently mixed in.
 - c. Disclosures of PHI via telephone are only permitted in limited circumstances due to the difficulty in verifying the identity of the person calling or receiving the call (see [Section 4.2](#)).
 - d. Telephone messages and appointment reminders may be left on answering machines and voice mail systems, unless the individual has requested alternative means of communication (see [Section 8.5](#)). However, messages should not contain information that links a patient's name to a particular medical condition, provides results or any other clinical information, or references any Highly Confidential Information.
- 3. Safeguards for Record Maintenance and Disposal
 - a. Record Storage
 - i. Areas where clinical records and other documents that contain PHI are stored must be secure.
 - ii. Wherever reasonably possible, the PHI will be stored in locked cabinets.
 - iii. Where locked cabinets are not available, the storage area must be locked when no member of the workforce is present to observe who enters and leaves. No unauthorized personnel may be left alone in such areas without supervision.
 - b. Keys and Access Codes
 - i. The unit's Security and Privacy Officers will develop a list of personnel and/or job title, who may have access to specific keys or access codes to storage cabinets and buildings.
 - ii. All keys must be signed out.
 - iii. All keys and identification cards must be surrendered upon termination of employment.
 - iv. The Covered Unit or Support Unit will change locks or access codes whenever there is evidence that a key or code is accessible to anyone other than an authorized member of the workforce, and presents a security threat that justifies the expense.
 - c. Removal of Records from Premises
 - i. Medical records and other documents containing PHI should not be removed from the premises except:
 - o If necessary to provide care or treatment to a patient;
 - o For purposes of official city business between internal departments;

SAFEGUARDING PROTECTED HEALTH INFORMATION

- For purposes of responding to a subpoena, court order, or as otherwise required by law.
 - ii. Documents containing PHI that have been taken off the premises may not be left unattended in places where unauthorized persons can gain access (for example, in automobiles or in view of passers-by).
- d. Disposal of PHI
 - i. All documents and materials containing PHI should be shredded when no longer needed (or, if not possible, be disposed of by an alternate method of disposal that ensures all patient identifiers are removed or destroyed).
 - ii. Before disposing of equipment such as copiers, medical equipment, computers or any other equipment capable of storing PHI, security procedures must be followed to ensure the PHI has been completely destroyed.
- 4. Safeguards for Computers and Mobile Devices
 - i. Workforce members are prohibited from sharing passwords or any other log-in credentials.
 - ii. Any member of the workforce who is expressly authorized to work from an off-site location and method must assure that he/she complies with all applicable policies and procedures regarding the security and privacy of PHI.
 - iii. Workforce members may not use personal email accounts to receive, maintain, or transmit PHI.
 - iv. Workforce members may not copy or download PHI to a non-City storage location such as a hard drive, CD, DVD, flash drive, laptop, phone, or other storage device.
 - v. Any laptop or mobile device that is used to create, access, or store PHI must be encrypted.

D. References: 45 CFR § 164.530(c)

REPORTING INCIDENTS

7.0 Reporting Incidents

A. Purpose

1. An unauthorized access, acquisition, use, or disclosure of protected health information ("PHI") may result in harm to the individuals whose information was compromised and erode trust in the City.
2. Responding quickly to any potential incident is vital to protecting the individuals and the City. Steps must be taken to stop the incident from continuing, investigate what occurred, mitigate any harm resulting from the incident, and determine how to prevent a reoccurrence of the incident.
3. HIPAA and other laws require that certain incidents be reported to the individual(s) whose information was compromised, the media, the U. S. Department of Health and Human Services ("DHHS"), and, in some cases, consumer reporting agencies.

B. Policy

1. All workforce members are required to promptly report any suspected privacy or security incident. An **"incident"** is any acquisition, access, use, or disclosure of PHI in a manner not permitted by:
 - a. the HIPAA Rules or other privacy laws,
 - b. an applicable business associate agreement or MOU with a Support Unit,
 - c. City privacy policies and procedures, or
 - d. unit-specific privacy policies, procedures, or protocols.
2. Following the procedures below, every reported incident will be investigated and action will be taken to stop the incident from continuing, manage any harm resulting from the incident (also known as "mitigation"), and determine how to prevent a reoccurrence of the incident.
3. The unit's Privacy Officer/Liaison will take the lead in investigating the incident, directing immediate action be taken to stop the incident from continuing, promptly notifying the City HIPAA Privacy Officer ("CHPO"), and working with the CHPO to take the steps outlined below.
4. The CHPO will determine whether an incident is a HIPAA **"Breach,"** which is a specific type of incident the meets the following criteria:
 - a. an acquisition, access, use, or disclosure of PHI in a manner not permitted by HIPAA,
 - b. that compromises the privacy or security of the PHI, as determined by a risk assessment conducted by the CHPO.
5. The CHPO (with the Breach Response Team, when the incident is a Breach) will advise the unit's Privacy Officer/Liaison regarding mitigating any damage, providing notification as required by HIPAA and other applicable law, and taking appropriate corrective action.

C. Procedures

1. Mandatory Duty to Report All Incidents
 - a. Any workforce member who suspects or becomes aware of an incident **must immediately (no later than the next business day) notify** his/her supervisor or unit manager.
 - b. The workforce member, together with his/her supervisor or unit manager, will complete Part I of the Incident Report Form (*see Form 7.0*) and provide it to the unit's Privacy Officer/Liaison no later than two business days after notifying the supervisor or unit manager of the incident.
 - c. A workforce member may report an incident directly to the unit's Privacy Officer/Liaison instead of his or her supervisor or unit manager. In such case, the workforce member must provide notification no later than the next business day after becoming aware of the incident, and submit the report no later than two business days after providing notification.

REPORTING INCIDENTS

2. Investigation

- a. As soon as possible after learning about an incident, the Privacy Officer/Liaison will work with the supervisor, unit manager, and others to take the necessary actions to stop the incident from continuing (for example, immediately suspending system access privileges).
- b. The Privacy Officer/Liaison will lead an investigation of the incident. The investigation will include gathering evidence and performing interviews to determine the facts of the incident (what, where, when, who, why, how) and completing Section II of the Incident Report Form.
- c. The Privacy Officer/Liaison will identify actions needed to mitigate any harmful effects of the incident, for example, instructing a person who received PHI in error to destroy it and state in writing that the PHI was not used inappropriately and will not be further used or disclosed.
- d. If the incident involved electronic PHI, the Privacy Officer will notify the unit's Security Officer and collaborate in performing the steps listed in paragraphs (a)-(c) above.

3. Risk Assessment

- a. As soon as possible, but no later than five business days after becoming aware of an incident, the Privacy Officer/Liaison will provide a completed Incident Report to the CHPO.
- b. The CHPO will review the Incident Report, obtain any additional information needed from the Privacy Officer/Liaison, and conduct a risk assessment to determine whether the facts indicate a low probability that the privacy or security of the PHI was compromised. The risk assessment will analyze the following factors:
 - i. The nature and extent of the PHI involved, including the types of identifiers and likelihood of re-identification;
 - ii. The unauthorized person who used the PHI or to whom the disclosure was made;
 - iii. Whether the PHI was actually acquired or viewed; and
 - iv. The extent to which the risk to the PHI has been mitigated.
- c. Based on the risk assessment, the CHPO will conclude whether the incident is a Breach and determine what individual, governmental, or other notice is required by state or federal law.
- d. The CHPO will consult with the City HIPAA Security Officer ("CHSO") as needed.

4. Mitigation and Corrective Action

- a. If the incident is a Breach, the CHPO will notify the Breach Response Team, which will include the CHPO (or designee), the CHSO (or designee), the unit's Privacy Officer/Liaison, the unit's Security Officer, and other persons the CHPO decides to include depending on the circumstances of the Breach.
- b. The Breach Response Team will:
 - i. determine whether the mitigation steps taken or planned are appropriate to adequately address the potential harm resulting from the Breach and provide advice on any additional steps to be taken; and
 - ii. identify the root cause(s) of the incident and the corrective action needed to prevent similar incidents from reoccurring.
- c. For incidents that are not Breaches, the Privacy Officer/Liaison will identify appropriate mitigation steps and corrective action in consultation with the CHPO. The CHPO may choose to involve the Breach Response Team depending on the circumstances of the incident.
- d. The Privacy Officer/Liaison will report the Breach Response Team's conclusions to the head of the Covered or Support Unit, who will ensure that appropriate actions are taken. If workforce sanctions are necessary, the head of the Covered or Support Unit will ensure that the sanctions are imposed according to the applicable disciplinary action policies (see [Section 9.3](#)).

5. Breach Notification

- a. The CHPO will advise the Privacy Officer/Liaison regarding what notification is required (see [Table 7.0](#)) and provide specific instructions as to the content and manner of the notification.

REPORTING INCIDENTS

- b. Notifications to the individuals affected by the Breach and the media (when required) will include the following information to the extent possible:
 - i. a brief description of what happened,
 - ii. the date of the breach and the date that the breach was discovered,
 - iii. the types of PHI involved in the breach,
 - iv. any steps the individual should take to protect themselves from potential harm resulting from the breach,
 - v. a brief description of what the City is doing to investigate the breach and mitigate any harm resulting from the breach, and
 - vi. a toll-free number, email address, or postal address for individuals to contact the Privacy Officer/Liaison with any additional questions.
 - c. If individual notifications are sent by the unit, the Privacy Officer/Liaison will provide the CHPO with a copy of the final letter and confirmation that all affected individuals were notified.
 - d. The CHPO (or designee) will provide notifications to DHHS in the manner specified by DHHS.
 - e. If the incident triggers the notification requirements of the Pennsylvania Breach of Personal Information Act or other applicable law, the CHPO will ensure that all necessary parties are notified.
6. Documentation
- a. The Privacy Officer/Liaison will maintain complete documentation of the internal investigation, mitigation steps taken and implemented, breach notification materials (including letters sent and records of attempts to contact), corrective action taken, and related information as part of the unit's HIPAA Documentation (see [Section 9.5](#)).
 - b. The CHPO will maintain copies of all Incident Report Forms received, documentation of the risk assessments performed, and copies of any notifications made by the CHPO.
 - c. The Privacy Officer/Liaison will compile periodic reports of incidents affecting his/her unit and will provide reports upon request to the CHPO. The CHPO will periodically report incidents and breaches to the HIPAA Steering Committee.

D. References: 45 CFR § 164.402, 164.404, 164.406, 164.408

TABLE 7.0: BREACH NOTIFICATION

Notification to:	<i>the Individual</i>	<i>the Secretary of DHHS</i>	<i>the Media</i>
Breach Involving: fewer than 500 people	Required without unreasonable delay, no later than 60 days after discovery of the incident.	Required electronically, no later than 60 days after the close of the previous calendar year.	Not required.
500 or more people	Same as above.	Required electronically as soon as possible, but no later than 60 days after the breach was discovered. Must be made concurrently with the individual notifications.	Must be provided in major print or broadcast media where the affected individual(s) likely reside, no later than 60 days after discovery of the incident.

HONORING AN INDIVIDUAL'S RIGHTS

8.0 Honoring an Individual's Rights

HIPAA gives individuals rights to control their own health information, including the right to get a copy of the information, make sure it is correct, and know who has seen it. As discussed further below, these rights can also be exercised by a personal representative authorized to make decisions on behalf of the individual.

8.1 RIGHT TO DESIGNATE A PERSONAL REPRESENTATIVE

A. Purpose

1. HIPAA recognizes that there may be times when individuals are legally or otherwise incapable of exercising their rights, or simply choose to designate another person to act on their behalf with respect to these rights. In such cases, a personal representative may be appointed by a court or other legal process, or designated by the individual through a legal document such as an advance directive or power of attorney.
2. A personal representative is legally authorized to act on the individual's behalf and should be treated the same as the individual for HIPAA purposes (with a few exceptions, see below).
3. The personal representative's authority to act for the individual may be limited or specific to particular health care decisions. In such cases, the personal representative should only be given access to the individual's PHI to the extent relevant to those specific matters.

B. Policy

1. In applying HIPAA policies and procedures, a personal representative will be given the same authority and rights as the individual to whom the PHI pertains, to the extent the personal representative is legally authorized to:
 - a. Make health care decisions on behalf of the individual, or
 - b. Act on behalf of a deceased individual or the deceased individual's estate.
2. Exceptions: a person will NOT be treated as a personal representative when:
 - a. It is reasonably believed that an individual has been or may be subjected to domestic violence, abuse, or neglect by the personal representative;
 - b. It is reasonably believed that treating such person as the personal representative could endanger the individual; or
 - c. A workforce member who is a licensed health care professional determines, in the exercise of professional judgment, that it is not in the best interest of the individual to treat the person as the individual's personal representative.
3. Special considerations for minors.
 - a. An **emancipated minor** will be given the same authority and rights as an adult for HIPAA purposes. Emancipation can be obtained by court order and is based on the minor living independently and supporting him or herself. A minor is also considered to be emancipated if he or she has married or joined the military.
 - b. A parent, guardian, or other person acting in loco parentis ("parent") is usually the personal representative of an unemancipated minor and can exercise the child's rights with respect to PHI, with a few exceptions (listed in the next paragraph).
 - c. An **unemancipated minor** will be given the same authority and rights as an adult for HIPAA purposes, in the following situations:
 - i. When state or other law allows a minor to consent to a particular health care service, without parental or other consent, and the minor consents to such treatment.

HONORING AN INDIVIDUAL'S RIGHTS

- (a) In Pennsylvania a minor can consent to all medical, dental, and other health services, except abortion, if the minor has: (1) graduated from high school, or (2) been married, or (3) been pregnant.
 - (b) In addition, any minor can consent to specific types of care, such as contraceptive care and counseling, testing and treatment for pregnancy except abortion, testing and treatment for STDs, counseling and care related to substance abuse, mental health care (if the minor is age 14 or older), or treatment following sexual assault.
- ii. When someone other than the parent is authorized by law to consent to the provision of a particular health service to a minor and provides such consent.
 - (a) For example, a court may grant authority to make health care decisions for the minor to an adult other than the parent, to the minor, or the court may make the decision(s) itself.
 - (b) In Pennsylvania, a minor who wants an abortion without parental consent can seek a court order consenting to the abortion.
- iii. When a parent agrees to a confidential relationship between the minor and a health care provider. For example, a physician asks the parent of a 16-year-old if the physician can talk with the child confidentially about a medical condition and the parent agrees.
- d. The City will comply with Pennsylvania or other laws governing parental access to a minor child's PHI in specific situations, as follows:
 - i. If the law *requires or permits* the parent to be given access to their minor child's PHI, the PHI may be disclosed even if the parent is not the child's personal representative. For example, Pennsylvania law requires parents or guardians to receive notice when minors between the ages of 14 and 17 admit themselves for inpatient mental health treatment. In such case, the fact that the minor has been admitted for treatment will be disclosed to the parent but no additional PHI.
 - ii. If the law *prohibits* a parent from accessing their minor child's PHI, the City will not disclose the PHI even if the parent is the child's personal representative.
 - iii. If there is *no applicable law* and the parent is not the child's personal representative, a City health care professional, in the exercise of professional judgment, may decide whether to allow or deny such access to further the child's best interests.

C. Procedures

1. To determine whether (and to what extent) a person is legally authorized to act as a personal representative, workforce members will request documentation consistent with [Table 8.1](#). The Law Department will make a determination in any situation not reflected on the table.
2. If a parent is requesting PHI about an unemancipated minor, and the facts indicate that one of the exceptions applies (a situation in which the unemancipated minor is able to consent to his or her own health care listed in paragraph B(C)(3) above), the parent should not be given access to the PHI. Such request should be referred to the unit's Privacy Officer for review, in consultation with the City HIPAA Privacy Officer.

D. References: 45 CFR § 164.502(g)

HONORING AN INDIVIDUAL'S RIGHTS

TABLE 8.1: DOCUMENTATION REQUIREMENTS FOR A PERSONAL REPRESENTATIVE

IF THE INDIVIDUAL IS:	THE PERSONAL REPRESENTATIVE IS:
An Adult or Emancipated Minor	A person with legal authority to make health care decisions on behalf of the individual <i>Required documentation:</i> Health care power of attorney Court appointed legal guardianship papers General power of attorney or durable power of attorney that includes the power to make health care decisions
An Unemancipated Minor	A parent, guardian, or other person acting in loco parentis with legal authority to make health care decisions on behalf of the minor child <i>Required documentation:</i> An adult will be recognized as the parent of an unemancipated minor child if: • He or she identifies himself or herself as the parent, and the adult and child share the same address; or, • If the adult is known by the workforce member to be the child's parent or guardian; • If the child is identified on a health insurance identification card or other documentation as a dependent covered by that adult's health insurance; or, • If the adult presents documentation of guardianship. EXCEPT WHEN: the minor has graduated from high school, been married, or been pregnant, OR if a workforce member believes that a parent should not be treated as a personal representative due to the minor having consented to: • contraceptive care or counseling, • testing and treatment for pregnancy except abortion, • testing and treatment for STDs, • counseling and care related to substance abuse, • mental health care (if the minor is age 14 or older), or • treatment following sexual assault.
Deceased	A person with legal authority to act on behalf of the decedent or the estate <i>Note:</i> Disclose only the PHI necessary for the requestor to fulfill his or her responsibilities to administer the deceased individual's estate or affairs. <i>Required documentation:</i> Executor or administrator of the estate: letters testamentary, court order, or will Next of kin (consult Law Department): proof of their relationship with the deceased (e.g., a marriage certificate, death certificate or birth certificate identifying the relationship). Does not apply to the release of mental health or substance abuse treatment records.

HONORING AN INDIVIDUAL'S RIGHTS

8.2 RIGHT TO ACCESS, INSPECT, AND OBTAIN A COPY

A. Purpose

1. Providing individuals with easy access to their protected health information (PHI) empowers them to be more in control of decisions regarding their health and well-being.
2. HIPAA requires covered entities to provide individuals, upon request, with access to the PHI about them in one or more "designated record sets" maintained by or for the covered entity. This includes the right to inspect or obtain a copy of the record, or to direct the covered entity to transmit a copy to a designated person or entity of the individual's choice.
3. A request for access is initiated by the individual or personal representative, as opposed to an Authorization which documents the individual's permission for a certain use or disclosure (and is often initiated by someone other than the individual).

B. Policy

1. As a general rule, Covered Units will provide individuals with access to their PHI upon request, as further detailed in this policy.
2. Certain types of PHI are exceptions to this policy and will not be provided, including:
 - a. PHI that is not part of the Covered Unit's designated record set (see [Section 3.2](#));
 - b. Psychotherapy notes, which are the personal notes of a mental health care provider documenting or analyzing the contents of a counseling session, that are maintained separate from the rest of the patient's medical record; or
 - c. Information compiled in reasonable anticipation of, or for use in, a civil, criminal, or administrative action or proceeding.
3. Covered Units may deny a request for access in certain situations, as listed below. If a request involves PHI in one of these categories and other PHI that is not, the individual will be granted access to all other requested PHI to the extent possible (a partial denial).
 - a. **Unreviewable grounds for denial** include the following:
 - i. When the PHI requested is not subject to the right to access (listed above);
 - ii. If the Covered Unit has provided health care to an inmate under the direction of a correctional institution, and providing the PHI would jeopardize the health, safety, security, custody, or rehabilitation of the individual, other inmates, or the safety of any officer, employee, or other person at the correctional institution or someone responsible for the transport of the inmate;
 - iii. If the PHI was created or obtained in the course of research that includes treatment (during a clinical trial, for example) and the individual agreed to the denial of access when consenting to the research (access may be temporarily suspended for as long as the research project is in progress); or
 - iv. When the PHI was obtained from someone other than a health care provider, under a promise of confidentiality, and access by the patient would be reasonably likely to reveal the source of the information.
 - b. **Reviewable grounds for denial** include the following situations in which a licensed health care provider, in the exercise of professional judgment, has determined that:
 - i. The access requested is reasonably likely to endanger the life or physical safety of the individual or another person. This ground for denial does not extend to concerns about psychological or emotional harm (e.g., concerns that the individual will not be able to understand the information or may be upset by it).
 - ii. The access requested is reasonably likely to cause substantial harm to a person (other than a health care provider) referenced in the PHI.
 - iii. The request for access is made by the individual's personal representative and provision of access to that person is reasonably likely to cause substantial harm to the individual or another person. For

HONORING AN INDIVIDUAL'S RIGHTS

example, a record that identifies the patient as a victim of abuse, and names the personal representative as the perpetrator (see [Section 8.1](#)).

4. When a request is denied in whole or in part, the individual will be sent a denial notice that includes the following:
 - a. The basis for the denial;
 - b. An explanation of the individual's rights to request a review, in applicable;
 - c. A description of how the individual may make a complaint to the Covered Unit or the Secretary of DHHS; and
 - d. If access is denied because the Covered Unit does not maintain the PHI in its designated record set(s), the notice will include any information the Covered Unit has regarding the location of the requested information.
5. When the reason for denial is subject to review and the individual requests a review, the Covered Unit will conduct a review to determine whether the standards of this policy were properly applied in the original denial.
6. Covered Units will not impose unreasonable measures on an individual requesting access that serve as barriers to or unreasonably delay the individual from obtaining access. For example, a Covered Unit may not require an individual who wants a copy of her medical record mailed to her home address to physically come to the office to request access and provide proof of identity in person.
7. Covered Units will provide the individual with access to the PHI in the form and format requested, if readily producible in that form and format, or if not, in a readable hard copy form or other form and format as agreed to by the covered entity and individual. A summary of the information will be provided, the individual requests a summary and agrees to the associated fee in advance.
8. Covered Units will comply with the following timelines in processing requests for access:
 - a. Within 30 days of the date of the request, the Covered Unit must provide access, request an extension, or issue a notice of denial for information that is maintained onsite.
 - b. One extension of up to 30 days is permitted for information that is maintained offsite or is not readily accessible. Requests for extension must be in writing, state the reasons for the delay, and the date by which the patient will either be granted access or receive a notice of denial.

C. Procedures

1. Receiving a request for access.
 - a. Requests for access must be in writing, be signed by the individual, and must clearly identify the designated recipient, the PHI being requested, and where to send the PHI.
 - b. A Covered Unit may require a specific request form be completed, provided the unit's form and protocol regarding use of the form has been approved by the CHPO.
 - c. Workforce members will direct any request for access to the workforce member(s) designated to review and process such requests.
2. Reviewing the request for access.
 - a. The designated workforce member(s) will review the access request to ensure it meets the requirements of paragraph C(1)(a) and will perform an identity check to verify that the requesting party is the individual to whom the PHI pertains or an authorized personal representative (see [Section 4.2](#)).
 - b. The designated workforce member(s) will approve or make a recommendation to deny the requested access.
3. Processing approved requests for access.
 - a. The workforce member who is authorized to release PHI in response to an approved request for access will locate the requested PHI and provide it in the requested form or format.

HONORING AN INDIVIDUAL'S RIGHTS

- b. The PHI will be provided to the designated recipient, in the manner requested by the individual (in person, by mail, etc). If the individual has requested the PHI be sent via e-mail, the e-mail address must be clearly written on the request and the individual must have been warned of, and accepted, the risks associated with receiving PHI through unencrypted e-mail.
 - c. The Covered Unit will not charge more than a flat copying fee of \$6.50 per request, unless an alternate fee schedule has been approved by the CHPO in a unit-specific protocol.
- 4. Processing denied requests for access.
 - a. If the Privacy Officer (or designee) agrees with recommendation to deny a request, he or she is responsible for sending the individual a denial notice that includes the required information.
 - b. When the reason for denial is subject to review and the individual requests a review, a review will be conducted by a member of the Covered Unit's management who has not participated in the original decision to deny access, the CHPO, or another reviewer designated in an approved unit-specific protocol.
 - c. The reviewer will provide written notice to the individual of the final determination.
- 5. Documentation. A copy of the request for access will be saved in the individual's record, along with either (a) documentation of the date and manner the request was fulfilled, or (b) copies of the denial notice, review notice, and all related correspondence.
- 6. The Covered Unit may develop unit-specific protocols providing more detailed instructions to its workforce members regarding the processing of requests for access. If such protocols differ from the procedural requirements in this Section (for example, if the Privacy Officer delegates any of his or her responsibilities to another workforce member), the Privacy Officer will obtain review and approval by the CHPO to ensure the protocols meet HIPAA requirements.

D. References: 45 CFR § 164.524

HONORING AN INDIVIDUAL'S RIGHTS

8.3 RIGHT TO CORRECT ERRORS

A. Purpose

1. HIPAA gives an individual the right to request that a covered entity correct any wrong information in his or her file or add information to the file if he or she believes something is missing or incomplete.
2. For example, an individual may review his or her file and see that an incorrect result has been recorded for a test. The individual may request that the provider correct the test result, and the provider must do so if there is no dispute that the information is mistaken. If the provider believes the test result is correct, the individual still has the right to have his or her disagreement noted in his or her file.
3. This Section provides standards and procedures for City workforce members to follow when receiving a request from a patient to correct his or her record (also known as a "request for amendment" in the HIPAA Rules).

B. Policy

1. Any Covered or Support Unit that maintains a designated record set (see [Section 3.2](#)) will allow individuals to request in writing that a correction be made to their records.
2. Requests for correction will be accepted and the appropriate amendment made, except when the information that is the subject of the request:
 - a. Is accurate and complete;
 - b. Was not created by the unit to whom the request was made (unless the originator of PHI is no longer available to act on the requested correction);
 - c. Is not part of the designated record set; or
 - d. Is not subject to the individual's right to access (see [Section 8.2](#)).
3. When a request is denied (due to meeting one of the above exceptions), the individual will be given an opportunity to submit a statement of disagreement.
4. Requests will be processed as specified in the below procedures, and action will be taken within 60 days of receiving the request. If needed, one 30-day time extension is permitted if the individual is notified (within the original 60 days) of the reasons for the delay and the date the request will be acted upon.
5. No original record will be deleted or altered. A correction will be made by identifying the information that is erroneous or incomplete, supplying the corrected information in a dated amendment, and providing a reference or link to the location of the amendment. This applies to both paper and electronic records.
6. If the record is corrected, or the individual disputes a correction that was denied, this information will be noted in the individual's record and will be included in any further disclosures of the individual's record.
7. The Privacy Officer of the Covered Unit maintaining the designated record set (or for whom a Support Unit maintains a designated record set) is responsible for receiving and coordinating responses to requests for correction and ensuring that the appropriate review, amendment, notifications, and documentation are completed in a timely manner.

C. Procedures

1. If an individual requests a correction to his or her record, provide the individual with the approved form and offer to help him or her complete the form. This form will ask the individual to identify the PHI that needs to be corrected, provide a reason, and list other persons or organizations that need to be notified if the correction is made.
2. All completed forms will be directed to the unit's Privacy Officer.
3. The Privacy Officer will coordinate a timely review of the individual's record, as follows:
 - a. The Privacy Officer will make a preliminary determination of whether the PHI is subject to an exception to this policy.

HONORING AN INDIVIDUAL'S RIGHTS

- b. The requested correction will be reviewed by the health care professional(s) who created the record. For a billing record or other type of non-clinical record maintained by a health plan, the requested correction will be reviewed by the workforce member who created the record (or management in the unit that is responsible for creating or making decisions on such type of record).
 - c. The reviewing health care professional or other workforce member will provide the Privacy Officer a decision regarding whether the requested correction should be accepted or denied, with an explanation of the basis for such decision.
- 4. If the **request is accepted**, the Privacy Officer will take the following steps:
 - a. Notify the individual (using an approved City or departmental form); and
 - b. Authorize the appropriate workforce members to correct the record by preparing an amendment to the record (for example, a "late entry" by the health care provider identifying what information was erroneous or incomplete and providing the correct information), which will be included in any future disclosures of the PHI;
 - c. Notify any other persons or organizations who received the erroneous record and may have relied on it, and any others that the individual has requested be notified about the correction.
- 5. If the **request is denied**, the Privacy Officer will take the following steps:
 - a. Notify the individual in writing containing the required elements (see 45 CFR § 164.526(d));
 - b. Allow the individual to submit a written statement disagreeing with the denial;
 - c. If needed, prepare a short rebuttal to the individual's statement of disagreement and provide a copy to the individual.
 - d. Coordinate with the appropriate workforce members to ensure the individual's record is updated so that any future disclosures of the PHI subject to the request will reflect:
 - i. If a statement of disagreement has been submitted, either (a) a copy of the request for correction, the denial of the request, the individual's statement of disagreement, and the covered entity's rebuttal, if any; or (b) an accurate summary of any such information; or
 - ii. If a statement of disagreement has not been submitted but the individual has requested such documentation, either (a) a copy of the request for correction and its denial; or (b) an accurate summary of such request and denial.
- 6. The Privacy Officer will ensure that the following documentation is maintained:
 - a. A copy of the individual's request, notification to the individual of acceptance or denial, and any other related correspondence will be maintained in the individual's record.
 - b. In addition, the Privacy Officer will maintain a log of all requests made and copies of all correspondence with the requesting individuals as part of the unit's HIPAA Documentation (see [Section 9.5](#)). Such documentation will be provided promptly to the City HIPAA Privacy Officer ("CHPO") upon request.
- 7. If the Covered Unit receives notification from another covered entity of a correction made by that entity, the Privacy Officer will coordinate with the appropriate workforce members to ensure the Covered Unit's designated record set(s) are updated to reflect the correction.
- 8. The Covered Unit may develop unit-specific protocols providing more detailed instructions to its workforce members regarding the processing of requests for correction. If such protocols differ from the procedural requirements in this Section (for example, if the Privacy Officer delegates any of his or her responsibilities to another workforce member), the Privacy Officer will obtain review and approval by the CHPO to ensure the protocols meet HIPAA requirements.

D. References: 45 CFR § 164.526

HONORING AN INDIVIDUAL'S RIGHTS

8.4 RIGHT TO KNOW HOW HEALTH INFORMATION IS USED OR DISCLOSED

A. Purpose

1. When receiving health care or health benefits, an individual might reasonably expect that a covered entity will use or disclose personal health information ("PHI") for reasons directly related to providing care or benefits, or when he or she has given permission for the covered entity to do so. The individual may be surprised to learn that the covered entity is allowed to make other uses and disclosures without his or her authorization.
2. HIPAA requires covered entities to develop and distribute a statement describing how the covered entity routinely uses and discloses PHI, called a **"Notice of Privacy Practices"** or "NPP." The NPP must provide a clear, user friendly explanation of individuals' rights with respect to their PHI and the privacy practices of health plans and health care providers.
3. In addition, HIPAA provides individuals the right to obtain a list of persons or organizations that have received their PHI from a covered entity or the covered entity's business associates for certain purposes, during the prior six years, called an **"accounting of disclosures."**

B. Policy

1. Each Covered Unit will maintain a Notice of Privacy Practices that has been approved by the City HIPAA Privacy Officer ("CHPO") and describes:
 - a. How the Covered Unit may use and disclose PHI about an individual.
 - b. The individual's rights with respect to their PHI and how the individual may exercise these rights, including how the individual may make a complaint about privacy violations.
 - c. The Covered Unit's legal duties with respect to the PHI, including a statement that the Covered Unit is required by law to maintain the privacy of PHI.
 - d. Who individuals can contact for further information about the Covered Unit's privacy policies.
2. Each Covered Unit will provide its NPP upon request to any person who asks for it and will prominently post its NPP on any web site it maintains that provides information about its customer services or benefits. In addition,
 - a. **Health plans** (DBHIDS and GHP) will:
 - i. Provide a copy of the NPP to new enrollees at the time of enrollment,
 - ii. Provide a revised NPP to all individuals covered by the plan within 60 days of any material revision, and
 - iii. Notify all individuals covered by the plan that they can obtain a copy, and how to do so, at least once every three years.
 - b. **Direct health care providers** (AHS, EMS, STDCP, and PNH) will:
 - i. Provide a copy of the NPP to the individual no later than the first date of service and make a good faith effort to obtain the individual's written acknowledgment of receipt of the NPP (except in an emergency). If the acknowledgment cannot be obtained, the provider must document his or her efforts to obtain the acknowledgment and the reason why it was not obtained.
 - ii. In an emergency, provide the NPP as soon as it is reasonably practicable to do so after the emergency situation has ended. A written acknowledgement is not required.
 - iii. Make the latest NPP (i.e., the one that reflects any changes in privacy policies) available at the provider's location(s) for individuals to request to take with them, and post it in a clear and prominent location at such location(s).
 - iv. If the first service delivery to an individual is provided over the Internet, the provider must send an electronic NPP automatically and contemporaneously in response to the individual's first request for service (via email or other electronic means). The provider must make a good faith effort to obtain a return receipt or other transmission from the individual in response to receiving the NPP.

HONORING AN INDIVIDUAL'S RIGHTS

3. Covered Units will provide an individual, upon request, with an accounting of all disclosures required by HIPAA to be included in such an accounting. [Table 4.3](#) lists the disclosures that are subject to the accounting, and the disclosures that are exceptions.

C. Procedures

1. The Privacy Officer for each Covered Unit is responsible to ensure that the unit's NPP is provided to individuals and posted as required by this policy. This includes:
 - a. Designating workforce members who are responsible for ensuring copies of the NPPs are available and that the NPP sign is prominently posted on the wall at all service locations;
 - b. Periodically checking that the NPPs for the Covered Units posted at www.phila.gov/privacy are the most recent versions, and that any other web site the Covered Unit maintains that provides information about its customer services or benefits links to the current NPP.
 - c. Advising the CHPO regarding any updates needed to the NPP due to changes in the Covered Unit's uses or disclosures of PHI or other practices or changes affecting the NPP.
2. The CHPO will maintain copies of the final versions of NPPs for each Covered Unit as part of the City's HIPAA Documentation (see [Section 9.5](#)).
3. Covered Units that are direct health care providers will save a copy of the individual's written acknowledgment of receipt of the NPP in the individual's record. An Acknowledgment only needs to be obtained once for each individual, at the initial service, but may be obtained more frequently based on unit-specific protocols or practices.
4. Any requests made by an individual for an accounting of disclosures will be immediately referred to the Privacy Officer, who will process such requests in consultation with the CHPO.

D. References: 45 CFR §§ 164.520, 164.528

HONORING AN INDIVIDUAL'S RIGHTS

8.5 RIGHT TO LIMIT CERTAIN USES AND DISCLOSURES

A. Purpose

1. To protect their confidentiality, individuals may wish to limit how their PHI will be used or disclosed by a covered entity. HIPAA gives individuals a right to request that covered entities limit their use or sharing of PHI that is not essential to providing quality health care or benefits to the individual, required by law, or needed for other public policy interests.
2. This policy provides standards regarding the following types of restrictions or limitations an individual may request:
 - a. Requests to restrict certain uses or disclosures of PHI, and
 - b. Requests to be contacted at a different place or by different means.

B. Policy

1. Individuals may **request to restrict certain uses or disclosures** of their PHI, as detailed below.
 - a. Each Covered Unit will allow an individual to request that the Covered Unit restrict its use or disclosure of such individual's PHI for the following purposes:
 - i. to carry out treatment, payment, or health care operations (see [Section 5.5](#)), or
 - ii. to family or others involved in the individual's care including disaster relief organizations (see [Section 5.4](#)).
 - b. A Covered Unit is not required to agree to an individual's request. There is one exception: when an individual has paid in full for an item or service (a self-pay service not billed to a health plan), the Covered Unit must agree to the individual's request to not disclose PHI related to that item or service to the health plan for the purposes of payment or health care operations.
 - c. The Covered Unit will not use or disclose PHI in violation of an agreed-upon restriction, except:
 - i. If the individual who requested the restriction is in need of emergency treatment and the restricted PHI is needed to provide such treatment, the Covered Unit may (a) use the PHI to provide emergency treatment to the individual, or (b) disclose the PHI to a health care provider to provide such treatment to the individual (in which case the Covered Unit must request the provider to not further use or disclose the PHI).
 - ii. A restriction that limits uses or disclosures beyond those listed in paragraphs B(1)(a)(i) or (ii) is not valid. For example, individuals do not have the right to restrict disclosures that are required by law such as for disease reporting to public health authorities and suspected child abuse in accord with Child Protective Services requirements.
 - d. A Covered Unit may terminate an agreed-upon restriction, when:
 - i. The individual agrees to or requests the termination in writing;
 - ii. The individual orally agrees to the termination and the oral agreement is documented; or
 - iii. The Covered Unit informs the individual that it is terminating its agreement to the restriction. Such termination is only effective for PHI that is created or received after the Covered Unit has informed the individual. It is not effective to terminate restrictions related to self-pay services (see paragraph B(1)(b) above).
2. Individuals may **request to be contacted in a confidential manner**, as detailed below.
 - a. Covered Units will accommodate reasonable requests by individuals to receive confidential communications of PHI, meaning the Covered Unit contacts the individual by alternative means or at alternative locations. For example, a patient may request that bills be sent to a post office box rather than to the address listed in his or her billing records.
 - b. A "reasonable" request for confidential communications must be in writing and must meet the following requirements:
 - i. Specify how payment will be handled, if the request involves a change in billing procedures.

HONORING AN INDIVIDUAL'S RIGHTS

- ii. Provide a specific alternative address and/or adequate details describing the alternative means of communication to be used.
- iii. If the means of alternative communication is costly (i.e., overnight courier service), make arrangements to pay the incremental cost.
- iv. If the request is made to a health plan, state that disclosure of all or part of the information to which the request pertains could endanger the individual. A Covered Unit that is a health care provider may not require an explanation from the individual as to the basis for the request for confidential communications.

C. Procedures

1. Any workforce member who receives a request described in this policy will promptly direct such request to the unit's Privacy Officer.
2. The Privacy Officer will review such request, and will take one of the following actions:
 - a. Approve the request and forward it to the appropriate workforce member for processing;
 - b. Deny the request and notify the individual; or
 - c. Consult another workforce member, for example, a health care provider, to determine whether the circumstances support agreeing to a restriction on the use or disclosure of the PHI and whether the proposed restriction would have a negative impact on the individual's care, payment for care, or administration of benefits.
3. The Privacy Officer is responsible for maintaining as part of the unit's HIPAA Documentation: a copy of any such request, the decision made, and related correspondence with the individual.
4. A copy of the request, the denial (if applicable), and related correspondence will be saved in the individual's record.
5. If the Covered Unit agrees to a restriction on the use or disclosure of PHI, it must be properly documented in the individual's file and communicated to workforce members or updated in medical record systems so that the PHI subject to the agreed-upon restriction is flagged.
6. The Covered Unit may develop unit-specific protocols providing more detailed instructions to its workforce members regarding the processing of such requests. If such protocols differ from the procedural requirements in this Section (for example, if the Privacy Officer delegates any of his or her responsibilities to another workforce member), the Privacy Officer will obtain review and approval by the CHPO to ensure the protocols meet HIPAA requirements.

D. References: 45 CFR §§ 164.502(c), 164.522(a) and (b)

HONORING AN INDIVIDUAL'S RIGHTS

8.6 RIGHT TO FILE A COMPLAINT

A. Purpose

1. Any person who believes a covered entity or business associate is not complying with the HIPAA Rules may file a complaint with the U.S. Department of Health and Human Services ("DHHS").
2. An individual may also make a complaint to a covered entity about its HIPAA policies and procedures, or its compliance with the HIPAA Rules or its HIPAA policies and procedures.

B. Policy

1. The City HIPAA Privacy Officer ("CHPO") is the City-designated contact to receive complaints from individuals (a) regarding the HIPAA compliance of any Covered Unit, Support Unit, or City workforce member, or (b) relating to any City or unit-specific HIPAA policy, procedures, or protocol.
2. The CHPO will collaborate with the unit's Privacy Officer, departmental leadership, and the City HIPAA Security Officer as necessary to investigate and resolve the complaint.
3. If, upon investigation of a complaint, the CHPO discovers conduct or facts indicating that a violation of HIPAA or HIPAA policies occurred, the CHPO will follow the mitigation, investigation, and notification procedures applicable to Privacy Incidents under [Section 7.0](#).
4. The CHPO will maintain documentation of any such individual complaint, including its investigation, and disposition, for at least six years following the resolution of such complaint.
5. The City will cooperate with any audits or investigations by DHHS relating to the City's HIPAA compliance. The CHPO is the designated contact for any such audits or investigations.

C. Procedures

1. Any HIPAA-related complaint received by a City workforce member will be immediately referred to the CHPO for investigation and resolution.
2. Any workforce member who receives a HIPAA-related complaint should take the following steps:
 - a. Direct the individual to document the complaint in writing.
 - b. Provide appropriate assistance to anyone needing help, including illiterate or non-English speaking patients.
 - c. Receive the written complaint from the individual and immediately forward it to the CHPO (see [Section 10](#) for contact information), or provide contact information and instruct the individual to send or deliver the complaint to the CHPO.
3. Any workforce member who receives a HIPAA-related communication, including an audit request or investigation notice, from DHHS will immediately notify the CHPO and the unit's Privacy Officer. The CHPO will collaborate with the unit's Privacy Officer, City leadership, the City HIPAA Security Officer, others within the Law Department, and/or any other persons as needed to respond to and cooperate with DHHS.

D. References: 45 CFR §§ 164.530(d), 160.306

ADMINISTRATION AND TRAINING

9.0 Administration and Training

The HIPAA Rules require covered entities to take steps to make sure their workforce members understand and are able to carry out their privacy and security responsibilities. For example, covered entities are required to officially designate the people or offices responsible for HIPAA compliance, complaints, and questions. In addition, covered entities must train their workforce members and impose disciplinary actions when HIPAA policies and procedures are violated. This Chapter describes how the City administers its HIPAA compliance program, provides training to its workforce, and imposes disciplinary action when necessary.

9.1 HIPAA OFFICIALS

A. Policy

1. Executive Order No. 4-17: HIPAA Compliance Directive (“E04-17”) officially establishes an executive-level Steering Committee authorized to approve and update the City’s hybrid designation, approve City-level HIPAA policies, oversee the City’s overall HIPAA compliance, ensure cooperation by Covered and Support Units in HIPAA compliance investigations and activities, and other related responsibilities.
2. E04-17 also officially designates the **City HIPAA Privacy Officer** (“CHPO”) and **City HIPAA Security Officer** (“CHSO”) as the officials with overall responsibility for City-level HIPAA compliance and administration.
 - a. The CHPO is responsible for:
 - i. monitoring the City’s HIPAA compliance and reporting periodically to the Steering Committee,
 - ii. approving unit-specific HIPAA policies, procedures, and protocols
 - iii. coordinating the investigation and reporting of HIPAA incidents,
 - iv. managing the City’s response to governmental audits and investigations, and
 - v. providing guidance to City departments and offices regarding the development, implementation, maintenance of, and adherence to HIPAA privacy policies, procedures, and workforce training.
 - b. The CHSO is responsible for overseeing all activities related to the development, implementation, management of, and adherence to the City’s policies, procedures, and workforce training ensuring the security, availability, and integrity of electronic PHI as required by the HIPAA Security Rule.
3. Each Covered and Support Unit will designate a **Privacy Officer/Liaison** to oversee HIPAA compliance and administration within that unit and serve as the unit’s liaison with the CHPO.
 - a. Each Covered Unit will designate a Privacy Officer, who will perform the duties specified in this Manual, including but not limited to the following:
 - i. Serving as a knowledgeable resource and modelling behavior consistent with HIPAA and other privacy laws and the City HIPAA policies and procedures;
 - ii. Monitoring overall compliance of the unit’s workforce members with City HIPAA policies and procedures and regularly reporting the unit’s compliance status to the CHPO;
 - iii. Implementing, updating, and monitoring compliance with unit-specific HIPAA protocols;
 - iv. Ensuring all workforce members have received appropriate HIPAA training and maintaining training records documenting all workforce training;
 - v. Promptly reporting any incidents to the CHPO and participating in the investigation of any incidents involving the unit, its PHI, or its workforce members;
 - vi. In collaboration with the Law Department and CHPO, ensuring the unit maintains and uses appropriate forms and notices, and updates such forms and notices as necessary;
 - vii. Ensuring the unit’s Notice of Privacy Practices is posted and distributed as required;
 - viii. Establishing and overseeing a process for tracking disclosures of PHI;
 - ix. Promptly reporting to the CHPO any individual complaints received or any correspondence from DHHS or other regulatory bodies regarding HIPAA matters;

ADMINISTRATION AND TRAINING

- x. Coordinating workforce disciplinary actions related to HIPAA violations;
 - xi. Maintaining a list of the unit's business associates, and monitoring compliance with business associate agreements;
 - xii. Maintaining all the unit's HIPAA Documentation and making it available upon request by the CHPO; and
 - xiii. Coordinating HIPAA compliance and oversight efforts with the unit's Security Officer.
- b. Each Support Unit will designate a Privacy Liaison, who will perform the same duties as listed above but only to the extent the Support Unit is providing a function or service for a Covered Unit that involves access to PHI.
4. The names and contact information for the CHPO and Privacy Officers are listed in [Section 10](#).
5. Responsibilities of unit-specific **Security Officers** are addressed in departmental HIPAA security policies and procedures.

B. Procedures

1. The CHPO and CHSO will be appointed as specified in EO4-17.
2. Privacy Officers will be appointed by the heads/directors of their respective Covered Units.
3. Privacy Liaisons will be appointed by the heads/directors of their respective Support Units, in collaboration with the Covered Unit(s) for which the Support Units are providing services.
4. Covered and Support Units will promptly notify the CHPO whenever a new Privacy Officer or Liaison is appointed and will, as much as possible, provide a period of transition during which the prior Privacy Officer/Liaison trains the newly appointed Privacy Officer/Liaison to ensure continuity of HIPAA compliance within the affected unit.

9.2 TRAINING AND EDUCATION

A. Policy

1. Covered Units are responsible for ensuring that all their workforce members receive HIPAA training. Support Units are responsible for ensuring that any of their workforce members who access PHI receive HIPAA training.
2. HIPAA training includes (a) the required City HIPAA training module, and (b) training specific to the activities and HIPAA protocols of the Covered or Support Unit.
3. HIPAA training will be provided to (a) all new workforce members as soon as possible but no later than 30 days after their start date; (b) all current workforce members affected by a significant change to the City or unit-specific policies and procedures, within 45 days of the change becoming effective; and (c) on a periodic basis as required to refresh the workforce members' knowledge and understanding of the HIPAA policies and procedures, preferably annually.

B. Procedures

1. All City workforce members who are subject to this policy Manual are required to complete the City HIPAA training module approved by the City HIPAA Privacy Officer ("CHPO"), currently available through the City's learning management system ("LMS").
2. Each Covered Unit's Privacy Officer is responsible for ensuring that all their workforce members complete the required City HIPAA training through the LMS within the required time limits. This includes identifying all workforce members who need to be trained, working with the CHPO and LMS staff to assign each workforce member the required training, following up with workforce members whose training has not been completed in a timely manner, and maintaining complete and accurate records of all workforce members who have been trained.

ADMINISTRATION AND TRAINING

3. Each Support Unit's Privacy Liaison is responsible for ensuring that all their workforce members who come into contact with PHI during the course of their duties complete the required City HIPAA training before receiving access to PHI. This includes the same steps listed in the previous paragraph (with respect to Covered Units).
4. In addition to the required City HIPAA training, each Covered Unit's Privacy Officer is responsible for creating and providing HIPAA training to all of the Covered Unit's workforce members on the Covered Unit's unit-specific HIPAA protocols.
5. Each Support Unit's Privacy Liaison will ensure that its workforce members who come into contact with a Covered Unit's PHI receive either unit-specific HIPAA training created by the Support Unit, or the Covered Unit's HIPAA training relevant to the PHI accessed by the Support Unit.
6. The Privacy Officer of each Covered Unit and the Privacy Liaison of each Support Unit will maintain records of all City and unit-specific HIPAA training of its workforce members for six years, and will provide training records demonstrating compliance with this policy to the CHPO upon request.

C. References: 45 CFR § 164.530(b)

9.3 SANCTIONS

A. Policy

1. City workforce members will be subject to disciplinary action for violation of City or unit-specific HIPAA policies and procedures. Violations that jeopardize the privacy or security of PHI are particularly serious and will subject the responsible workforce member(s) to disciplinary action up to and including termination of employment.
2. Disciplinary action will be administered in accordance with City disciplinary policies and contractual terms applicable to City workforce members.
3. Disciplinary actions resulting from violations of HIPAA policies or procedures will be documented by the unit's Privacy Officer/Liaison and maintained as part of the unit's HIPAA Documentation (see [Section 9.5](#)).

B. Procedures

1. Every workforce member is required to promptly report potential violations of these HIPAA policies and procedures (following the process described in [Section 7.0](#)).
2. After an Incident has been investigated by the unit's Privacy Officer/Liaison and reported to the City HIPAA Privacy Officer ("CHPO"), the Privacy Officer/Liaison will work with departmental management to determine what type of disciplinary action is warranted and to administer the appropriate action. A report will be provided to the CHPO confirming the date, name of workforce member(s) involved, and type of disciplinary action provided.
3. Disciplinary action will also be taken for violations of this policy Manual that do not result in an Incident, for example, failure to complete required HIPAA training in a timely manner.
4. [Table 9.3](#) provides guidance regarding types of disciplinary action warranted by various types of HIPAA violations; however, this guidance is subordinate to the City's human resources and other applicable disciplinary policies.

C. References: 45 CFR §§ 164.530(e), 164.308(1)

ADMINISTRATION AND TRAINING

TABLE 9.3: SAMPLE DISCIPLINARY ACTIONS RESULTING FROM HIPAA VIOLATIONS

Class	Examples of Violations	Examples of Disciplinary Actions
1	(1) Accessing information that you do not need to know to do your job; (2) Sharing your computer access codes (user name & password); (3) Leaving your computer unattended while you are logged into a PHI program; (4) Sharing PHI with another employee without authorization; (5) Copying PHI without authorization; (6) Changing PHI without authorization; (7) Discussing confidential information in a public area or in an area where the public could overhear the conversation; or (8) Discussing confidential information with an unauthorized person.	(a) Verbal reprimand; (b) Written reprimand in employee's personnel file; (c) Retraining on HIPAA awareness; (d) Retraining on City privacy and security policies and how they impact the employee and employee's department; or (e) Retraining on the proper use of internal forms and HIPAA required forms.
2	(1) Second offense of any class 1 offense (does not have to be the same offense); (2) Unauthorized use or disclosure of PHI; (3) Using another person's computer access codes (user name & password); or (4) Failure to comply with a Privacy Officer resolution or recommendation.	(a) Written reprimand in employee's personnel file; (b) Retraining on HIPAA awareness; (c) Retraining on City privacy and security policies and how they impact the employee and employee's department; (d) Retraining on the proper use of internal forms and HIPAA required forms; or (e) Suspension of employee (recommended suspension period: 1-3 days).
3	(1) Third offense of any class 1 offense (does not have to be the same offense); (2) Second offense of any class 2 offense (does not have to be the same offense); (3) Obtaining PHI under false pretenses; or (4) Using and/or disclosing PHI for commercial advantage, personal gain or malicious harm.	(a) Termination of employment; (b) Civil penalties as provided under HIPAA or other applicable Federal/State/Local law; or (c) Criminal penalties as provided under HIPAA or other applicable Federal/State/Local law.

ADMINISTRATION AND TRAINING

9.4 ANTI-RETALIATION

A. Policy

1. The City prohibits any intimidating or retaliatory acts be taken against any individual or other person (including a workforce member) for:
 - a. Exercising their rights or participating in any process established by the HIPAA Rules, such as filing a complaint with DHHS about City privacy policies or practices;
 - b. Testifying, assisting, or participating in an investigation, compliance review, proceeding, or hearing authorized by the HIPAA Rules; or
 - c. Opposing any act or practice that violates the HIPAA Rules, provided the individual or person has a good faith belief that the practice opposed is unlawful, and the manner of opposition is reasonable and does not involve a disclosure of PHI in violation of HIPAA.
2. Prohibited actions include any acts by City workforce members or business associates that threaten, intimidate, coerce, harass, discriminate against, or take any other retaliatory action against such individual or person for one of the activities listed above.

B. Procedures

1. Any workforce member who is aware of, or believes he or she is the victim of, intimidating or retaliatory acts committed by a City workforce member or business associate should report his or her concerns to the CHPO and/or the unit's Privacy Officer. Good faith reports made under this policy are also protected from retaliation.
2. Workforce members who are found to have committed intimidating or retaliatory acts prohibited by this policy will be subject to sanctions as set forth in [Section 9.3](#), up to and including termination.

C. References: 45 CFR §§ 160.316, 164.530(g)

9.5 HIPAA DOCUMENTATION

A. Policy

1. In general, medical and client records will be retained according to state and federal laws and regulations and in accordance with the City Records Management Policy and any departmental records retention protocols.
2. Documentation related to HIPAA compliance and administration is considered "**HIPAA Documentation**," and includes the following:
 - a. City HIPAA policies and procedures;
 - b. Unit-specific and departmental HIPAA policies, procedures, or protocols;
 - c. Any communication required by the HIPAA Rules (for example, requests by individuals and related correspondence, notices of privacy practices, etc);
 - d. Any action, activity, or designation that is required to be documented by the HIPAA Rules, (for example, employee disciplinary action records, risk assessment reports);
 - e. Incident documentation for any privacy and security incidents, and breach notification documentation for any Breaches (see [Section 7.0](#)); and
 - f. Business associate agreements with service providers and contractors.
3. HIPAA Documentation will be retained for a minimum of six years from the date of creation or the date when last in effect, whichever is later.

ADMINISTRATION AND TRAINING

B. Procedures

1. HIPAA Documentation may be maintained in either paper or electronic form, provided that any format is sufficiently protected to ensure it will be retrievable throughout the required retention period.
2. Unless otherwise indicated in this Manual, the Privacy Officer/Liaison will be responsible for maintaining all HIPAA Documentation relevant to his or her Covered or Support Unit.
3. Agreements with business associates that are not maintained in either ACIS or the Procurement e-contracting system must be maintained by the contracting Covered or Support Unit as part of its HIPAA Documentation.
4. The City HIPAA Privacy Officer will maintain the following types of HIPAA Documentation:
 - a. Decisions of the HIPAA Steering Committee;
 - b. City HIPAA privacy policies and procedures;
 - c. City HIPAA privacy training materials;
 - d. Risk assessments and notifications provided in response to incidents;
 - e. Investigations, audits, and other communications with DHHS;
 - f. Approved versions of each Covered Unit's Notice of Privacy Practices; and
 - g. Certain other HIPAA-related correspondence (i.e., complaints from individuals).

C. References: 45 CFR § 164.530(j)(1)

CONTACT INFORMATION

10.0 Contact Information

City Wide

Privacy Team



Contact the HIPAA Privacy Unit at HIPAAprivacy@phila.gov

Nancy Weinman
City HIPAA Privacy Officer
 Tel 215.683.5404
nancy.weinman@phila.gov

Julie Assis
 Divisional Deputy City Solicitor
 Tel 215.683.5251
julie.assis@phila.gov

Joseph Varallo
 Assistant City Solicitor
 Tel 215.683.5451
joseph.varallo@phila.gov

Security Team

Idris Hanns
City HIPAA Security Officer
 Tel 215.686.8175
idris.hanns@phila.gov

Kareem Booker
 Security Analyst
 Tel 215-686-8142
kareem.booker@phila.gov

Mohamed Konate
 Security Administrator
 Tel 215.686.8514
mohamed.konate@phila.gov

Covered Units

Privacy Officers

Dr. James Dean
 AHS Privacy Officer
 Tel 215.685.6762
james.dean@phila.gov

Kerry Buchs
 PHL Privacy Officer
 Tel 215.685.6812
kerry.buchs@phila.gov

Dr. Lenore Asbel
 STDCP Privacy Officer
 Tel 215.685.6617
lenore.asbell@phila.gov

Jeffrey Orlin
 DBHIDS Privacy Officer
 Tel 215.685.5476
jeffrey.orlin@phila.gov

Chief Arturo Alleyne
 EMS Privacy Officer
 Tel 215.685.4204
arturo.alleyne@phila.gov

Leontyne Freeman
 GHP Privacy Officer
 Tel 215.686.0612
leontyne.freeman@phila.gov

Security Officers

Mike Harris
 AHS, PHL, and STDCP Security Officer
 Tel 215.685.5376
mike.harris@phila.gov

Maureen Faulkner
 PNH Privacy Officer
 Tel 215-685-0800 ext. 1111
mfaulkner@fltcpnh.org

Phil Rohrbach
 DBHIDS Security Officer
 Tel 215.413.7558
phil.rohrbach@phila.gov

Jennifer Brennan
 EMS Security Officer
 Tel 215.439.5137
jennifer.brennan@phila.gov

Shipra Jha
 GHP Security Officer
 Tel 215.686.5083
shipra.jha@phila.gov

CITY HIPAA FORMS

City HIPAA Forms

FORM 7.0: INCIDENT REPORT FORM

Please click [here](#) to access the City's Incident Report Form. If you are viewing a paper copy of this Manual, the City's Incident Report form can be found at the following link: <https://goo.gl/N9v5Wf>.



City of Philadelphia HIPAA Policy Manual

Approval Authority:	HIPAA Steering Committee
Sponsoring Official:	First Deputy Managing Director
Subject Matter Expert:	Law Department, HIPAA Privacy Unit
Effective Date:	12/01/2017
Revision Dates:	12/01/2017

© City of Philadelphia 2017

This Manual and its contents were created exclusively for the City of Philadelphia. For permission to use or disclose the contents of this Manual outside the City of Philadelphia, please contact HIPAAprivacy@phila.gov.